

High-Level Design - Front Line Demand & Supply (FDS)



Royal Mail Group

Processing Sites Implementation

Based on the arc42 Template, v9.0

A worked-example reference document for Solution Architects across Royal Mail

Field	Value
Document Title	FDS Processing Sites - High-Level Design
Version	1.0
Status	Draft for Review
Author	Rashu Khanna (Solution Architect) Farrukh Nizami (Lead Solution Architect)
Document Owner	ART Programme
Classification	Template for Internal Use
Source Requirements	Processing - High Level Requirements (MDS_MVP)
Template	arc42 v9.0-EN

1. Introduction and Goals

Describes the relevant requirements and the driving forces that the software architects and development team must consider:

- Underlying business goals
- Essential features and functional requirements
- Quality goals for the architecture
- Relevant stakeholders and their expectations.

1.1. Requirements Overview

Short description of the functional requirements, driving forces, extract or abstract of requirements. Link to existing requirements documents with version numbers.

Contents

Short description of the functional requirements, driving forces, extract (or abstract) of requirements. Link to (hopefully existing) requirements documents (with version number and information where to find it).

Motivation

From the point of view of the end users a system is created or modified to improve support of a business activity and/or improve the quality.

Form

Short textual description, probably in tabular use-case format. If requirements documents exist this overview should refer to these documents. Keep these excerpts as short as possible. Balance readability of this document with potential redundancy w.r.t to requirements documents.

Royal Mail FDS - Processing Sites: Worked Example

Royal Mail operates a national network of Processing Sites - Mail Centres, RDCs, Hubs and Super Hubs, International, through which all letter and parcel volumes are sorted, consolidated, and dispatched. Workforce planning across this estate has historically relied on a combination of MDS (Master Duty System), spreadsheet-based duty rosters, and locally held overtime sign-off processes. This fragmentation creates discrepancies between planned hours, scanned attendance, and paid hours in PSP, with downstream consequences for cost recognition, finance reporting, and audit assurance.

The Front Line Demand and Supply (FDS) application already deployed for Delivery Offices is being extended to Processing Sites to provide a single, integrated, auditable workforce-planning platform across the frontline estate. The MVP scope is defined in the Processing - High Level Requirements artefact (story IDs MDS_MVP01_01 through MDS_MVP24_01).

Capabilities delivered by FDS at Processing Sites:

#	Capability	Description
1	Daily Attendance Planning	Structured scheduling interfaces for duty planning across delivery offices and processing sites. Consumes master duty and reference data from DDS for deliveries and MDS for Processing sites , establishing a standardised, auditable record of scheduling intent across the frontline estate.
2	Overtime Planning	A dedicated scheduling environment for overtime attendance across delivery offices and processing sites. Generates structured OT plans that serve as the authoritative reference for Qlik Reporting.
3	Overtime Timesheet	Cross-references the approved OT plan against real-time PDA and Console attendance scan data. Authorised personnel such as site managers, shift managers and book-room staff review and approve records for overtime payment processing via PSP.
4	Agency Timesheet	Cross-references agency worker shift plans against PDA and Console attendance scan data. Approved records are transmitted to the JoinedUp agency payroll platform via API, eliminating manual data re-entry and accelerating cost recognition.
5	RCS Reporting	Reconciles planned versus actual hours across delivery offices and processing sites, disaggregated by workforce category - AWD, overtime, and agency. Generates structured data sets consumed by Royal Mail's financial reporting infrastructure for cost governance and expenditure management.

Top-level functional requirements (Must-have, MVP):

- Import Processing duty data from MDS into FDS for all Mail Centres, Parcel Hubs and Super Hubs (MDS_MVP01_01).
- Allocate duty holders and rotation weeks against the imported duty data (MDS_MVP03_01–03).
- Generate, edit and view daily attendance plans for a four-weeks-past / four-weeks-future window (MDS_MVP04_01–08).
- Bring in and manage overtime duties from MDS, with auto-purge after four weeks (MDS_MVP19_01–03).
- Manually create and amend overtime duties locally (MDS_MVP05_01–02).
- Approve overtime against PDA / Console scan data and transmit authorised records to PSP (MDS_MVP10_01–05).
- Approve schedule attendance against scan data and transmit to PSP (MDS_MVP11_01–05).
- Provide Production Schedulers with 10-minute-granularity work-area headcount reports (MDS_MVP06_01).
- Provide WAM/PSM with Employee Line View and Work Area Line View, including print outputs (MDS_MVP07, MDS_MVP08).
- Merge the existing Deliveries and Processing SISO applications to remove the cross-access technical limitation (MDS_MVP16_01).

- Send reporting feeds (attendance plan, OT, headcount) from FDS to DP/Qlik and back to MDS (MDS_MVP14_01, MDS_MVP15_01).

Out-of-scope for MVP (recorded for traceability):

- Future Duty Planning of differing duty structures (MDS_MVP13_01 - Won't-have; duty data revisions are infrequent and master data refreshes monthly).
- Live Scan reporting and Pay-vs-Scan reporting in DP (MDS_MVP22, MDS_MVP23 - deferred).
- PSP integration for future-dated employee records (out of scope for MVP).

1.2. Quality Goals

Contents

The top three (max five) quality goals for the architecture whose fulfillment is of highest importance to the major stakeholders. We really mean quality goals for the architecture. Don't confuse them with project goals. They are not necessarily identical.

Motivation

You should know the quality goals of your most important stakeholders, since they will influence fundamental architectural decisions. Make sure to be very concrete about these qualities, avoid buzzwords. If you as an architect do not know how the quality of your work will be judged...

Form

A table with quality goals and concrete scenarios, ordered by priorities

Royal Mail FDS - Processing Sites: Worked Example

Priority	Quality Goal	Concrete Scenario / Acceptance Criterion
1	Auditability & Traceability	Every approved overtime, schedule-attendance and agency timesheet record carries a cryptographically immutable audit trail showing originating duty, scan events used for validation, approver identity and timestamp; complete trail retrievable within 5 seconds for any record over the last 7 years.
2	Pay Accuracy	For 99.5% of approved timesheet submissions, the hours transmitted to PSP / JoinedUp match the verified PDA/Console scan-derived hours to within ± 2 minutes; manual override events are logged and reportable.
3	Operational Availability	FDS web UI available 99.7% of the time during the operational window 24x7, with planned maintenance windows agreed with service; degraded-mode local edit-and-resync supported for up to 2 hours of integration outage.

Priority	Quality Goal	Concrete Scenario / Acceptance Criterion
4	Integration Reliability	Inbound MDS feeds processed within 30 minutes of receipt with 100% record-level reconciliation; outbound PSP/JoinedUp/DP feeds delivered within agreed SLAs and end-to-end reconciled daily.
5	Usability for Front-line Managers	A trained PSM completes a full-shift attendance plan adjustment (cover absence, extend AWD to OT, re-allocate to work area) in under 90 seconds

1.3. Stakeholders

Content

Explicit overview of stakeholders - all persons, roles or organizations that

- should know the architecture
- have to be convinced of the architecture
- have to work with the architecture or with code
- need the documentation of the architecture for their work
- have to come up with decisions about the system or its development

Motivation

You should know all parties involved in development of the system or affected by the system. Otherwise, you may get nasty surprises later in the development process. These stakeholders determine the extent and the level of detail of your work and its results.

Form

Table with role names, person names, and their expectations with respect to the architecture and its documentation.

Further Information

See [Introduction and Goals](#) in the arc42 documentation.

Role/Name	Contact	Expectations
<Role-1>	<Contact-1>	<Expectation-1>
<Role-2>	<Contact-2>	<Expectation-2>

Royal Mail FDS - Processing Sites: Worked Example

Role / Name	Contact	Expectations
Programme Sponsor	Phil / Martyn (Operations)	Delivers MVP capabilities to time and cost; gives go/no-go on requirement decisions; signs off MoSCoW and exclusions.
Solution Design	Rashu Khanna (SA)	Owens end-to-end solution, approves all integration and platform-level decisions, accountable for architectural integrity.
Processing Site Manager (PSM)	PSM community across Mail Centres, Parcel Hubs, Super Hubs	Daily attendance planning, OT planning, OT and schedule-attendance approval, duty-holder allocation, employee borrowing.
Pay Services	Payroll / Pay & Reward	Receives authorised OT and schedule-attendance records via integration; needs accurate, idempotent feeds.
JoinedUp Platform Owner	Agency payroll function	Receives authorised agency timesheets via API; expects reconcilable, replayable data flow.
MDS Owner	Alan Robers	Master data provider for duty sets; consumes FDS-back feeds (e.g. headcount).
DP / Qlik Reporting	Martyn	Consumes attendance, OT and compliance reporting data sets for enterprise reporting (Qlik / Qlik Sense).
Information Security & Data Protection	DPO	Confirms GDPR, role-based access and audit-log compliance; approves data-flow design.
Lead Architect	Farrukh Nizami	Confirms reuse of the FDS platform, alignment with integration standards and the cloud target operating model.

2. Architecture Constraints

Contents

Any requirement that constraints software architects in their freedom of design and implementation decisions or decision about the development process. These constraints sometimes go beyond individual systems and are valid for whole organizations and companies.

Motivation

Architects should know exactly where they are free in their design decisions and where they must adhere to constraints. Constraints must always be dealt with; they may be negotiable, though.

Form

Simple tables of constraints with explanations. If needed you can subdivide them into technical constraints, organizational and political constraints and conventions (e.g. programming or versioning guidelines, documentation or naming conventions)

Further Information

See [Architecture Constraints](#) in the arc42 documentation.

Royal Mail FDS - Processing Sites: Worked Example

2.1. Technical Constraints

ID	Constraint	Explanation
TC-01	Reuse the existing FDS platform	FDS is already deployed for Deliveries and Collection Points. The Processing extension must be implemented on the same platform to avoid bifurcating the front-line estate model and to leverage the existing operational, support and compliance posture.
TC-02	MDS is the system of record for duty data	All duty master data (duty codes, work-area splits, rotation patterns) originates in MDS. FDS holds an operational copy refreshed monthly and on demand it does not author duty in MVP
TC-03	PSP is the only payroll endpoint for AWD/OT/SA	Authorised overtime and schedule-attendance records must be submitted to PSP for payment. FDS must produce PSP-compatible records and reconcile their acceptance.
TC-04	JoinedUp is the agency payroll endpoint	Approved agency timesheets must be transmitted to JoinedUp via its supported API. No bypass route is permitted.

ID	Constraint	Explanation
TC-05	Scan data sources are PDA and Console only	Validation of attendance hours uses only RMG-issued PDA scans and Console-recorded scans. No third-party time clocks are in scope.
TC-06	Reporting flows into DP / Qlik	Strategic reporting consumes FDS data through the enterprise Data Platform (DP) and visualises it in Qlik / Qlik Sense. Bespoke reporting solutions are not permitted.
TC-07	Cloud-first hosting	New compute and integration components must run on the Royal Mail strategic cloud platform.

2.2. Organisational & Political Constraints

ID	Constraint	Explanation
OC-01	CWU and trade-union sensitivities	Workforce-affecting changes (rosters, OT, scan-based pay validation) must be deployable with appropriate consultation; the design must support phased site-by-site rollout.
OC-02	Working Time Regulations	The system must not facilitate non-compliant rest-period or maximum-hours patterns; warnings should surface at Over Time planning stage in FDS.
OC-03	GDPR	Personally Identifying Information (employee identifiers, scan timestamps, location) must be processed and retained in line with RMG's data-protection schedule.
OC-04	Audit	Cost-affecting flows (RCS reporting, PSP/JoinedUp submissions) require segregation of duties and immutable audit trails to meet internal-control requirements.

2.3. Conventions

ID	Convention	Explanation
CN-01	API-first integration	New integration points expose REST APIs published in the BIG APIM gateway and registered in the API catalogue.
CN-02	Event-driven scan ingestion	PDA and Console scan events are ingested through existing message queues hosted in the BIG IBM MQ, no direct point-to-point coupling.

ID	Convention	Explanation
CN-03	Documentation in arc42	All HLDs are authored using this template, stored in the Confluence space, and reviewed by the ARB Council before build start.

3. Context and Scope

Contents

Context and scope - as the name suggests - delimits your system (i.e. your scope) from all its communication partners (neighboring systems and users, i.e. the context of your system). It thereby specifies the external interfaces.

If necessary, differentiate the business context (domain specific inputs and outputs) from the technical context (channels, protocols, hardware).

Motivation

The domain interfaces and technical interfaces to communication partners are among your system's most critical aspects. Make sure that you completely understand them.

Form

Various options:

- Context diagrams
- Lists of communication partners and their interfaces.

3.1. Business Context

Contents

*Specification of **all** communication partners (users, IT-systems, ...) with explanations of domain specific inputs and outputs or interfaces. Optionally you can add domain specific formats or communication protocols.*

We need to put context diagram from C4 model but more oriented around interaction between business capability provide by the current system and other organizational business capabilities

Motivation

All stakeholders should understand which data are exchanged with the environment of the system.

Form

All kinds of diagrams that show the system as a black box and specify the domain interfaces to communication partners.

Alternatively (or additionally) you can use a table. The title of the table is the name of your system, the three columns contain the name of the communication partner, the inputs, and the outputs.

<Diagram or Table>

<optionally: Explanation of external domain interfaces>

Royal Mail FDS - Processing Sites: Worked Example

FDS Processing Sites - Business Context:

Communication Partner	Inputs to FDS	Outputs from FDS
MDS (Master Duty System)	Master duty data, work-area splits, rotation patterns, processing-site reference data, OT duties, employee assignments to duties.	Headcount report and other operational reports back to MDS.
PSM (Processing Site Manager)	Duty-holder allocation, daily attendance plan adjustments, OT shift creation, employee site loans, OT and SA approvals.	Daily attendance plan, work-area split view, OT plan, four-week past/future planning view.
WAM (Work Area Manager)	Local read; print requests for shift output.	Employee Line View and Work Area Line View, hours-by-employee and hours-by-area, printable splits.
Production Scheduler	Report parameter requests (site, date range).	10-minute-granularity headcount-by-work-area report; total hours by shift and by day.
Site Manager / Book-room	Offline-validated OT confirmations; review actions.	OT approval queue, scan-vs-plan reconciliation.
PDA and Console	Employee scan-on / scan-off events with timestamp and location.	one-way ingest
RMG HR System (Employee Payrolls)	bi-directional	Authorised OT and Schedule-Attendance records for payroll processing.
Agency Payroll System	API acknowledgements; rejection reasons.	Approved agency timesheets via API.
Reporting and Visualisation	One-way egress	Attendance plan, OT, compliance and RCS data feeds.
User Identities	User identity and group membership.	Authentication assertions via SSO redirect.

3.1.1. Business Context - Diagram

A C4-style System Context diagram should be inserted here in production usage.

<placeholder>

3.2. Technical Context

Contents

Technical interfaces (channels and transmission media) linking your system to its environment. In addition a mapping of domain specific input/output to the channels, i.e. an explanation which I/O uses which channel.

We need to put context diagram from C4 model but more oriented around interaction between the current system and other RMG systems and external systems.



We must ALSO include **Big Picture** here

ART Phase 4 & 5 | Architectural Impact Assessment

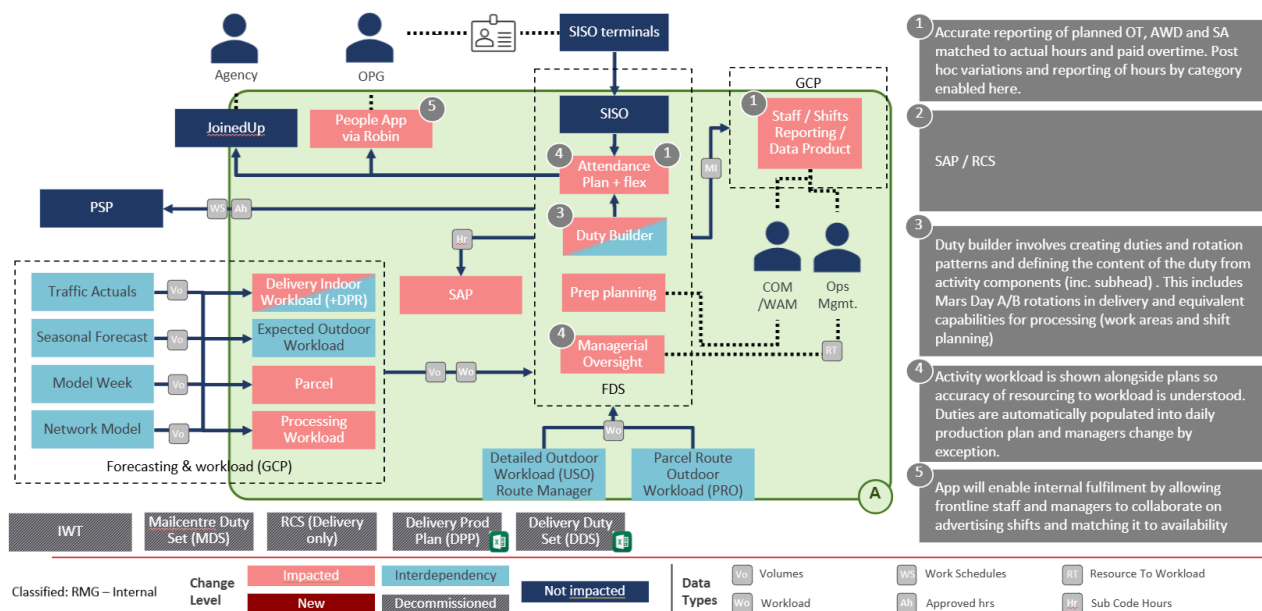


Figure 1. Big Picture

Motivation

Many stakeholders make architectural decision based on the technical interfaces between the system and its context. Especially infrastructure or hardware designers decide these technical interfaces.

Form

E.g. UML deployment diagram describing channels to neighboring systems, together with a mapping table showing the relationships between channels and input/output.

<Diagram or Table>

<Optionally: Explanation of technical interfaces>

<Mapping Input/Output to Channels>



Conceptual diagram is replaced with business and technical context diagrams. We

will use Context diagrams from C4 model here.

Further Information

See [Context and Scope](#) in the *arc42* documentation.

Royal Mail FDS - Processing Sites: Worked Example

Partner	Channel	Protocol / Format	Direction & Cadence
MDS	Direct – Sharepoint	FTPS	Inbound: monthly bulk + on-demand delta. Outbound: scheduled report.
PSP	MQ	AQMP - XML	Outbound: per approval event, near-real-time.
JoinedUp	API Gateway → JoinedUp public API	REST/JSON over HTTPS	Outbound: per approved agency timesheet.
PDA estate	IBM MQ	AQMP - JSON	Inbound: continuous stream.
Console	IBM MQ	AQMP - JSON	Inbound: continuous stream.
DP / Qlik	BIG MFT	FTPS - CSV	Outbound: T+1 data sets.
Active Directory / SSO	Identity provider (Entra ID)	SAML	Inbound: per-user auth.

3.2.1. Technical Context - Diagram



Figure 2. Technical Context

4. Solution Strategy

Contents

A short summary and explanation of the fundamental decisions and solution strategies, that shape system architecture. It includes

- technology decisions
- decisions about the top-level decomposition of the system, e.g. usage of an architectural pattern or design pattern
- decisions on how to achieve key quality goals
- relevant organizational decisions, e.g. selecting a development process or delegating certain tasks to third parties.

Motivation

These decisions form the cornerstones for your architecture. They are the foundation for many other detailed decisions or implementation rules.

Form

Keep the explanations of such key decisions short.

Motivate what was decided and why it was decided that way, based upon problem statement, quality goals and key constraints. Refer to details in the following sections.

Further Information

See [Solution Strategy](#) in the arc42 documentation.

Royal Mail FDS - Processing Sites: Worked Example

The FDS Processing Sites architecture is governed by five fundamental decisions:

4.1. Reuse, do not re-platform

FDS is extended, not rebuilt. Processing capabilities are added as additional bounded contexts within the existing FDS solution, sharing identity, audit, integration, master data and storage layers. This delivers cost containment and consistency across Delivery and Processing Units.

4.2. Data-driven planning

Duty masters (codes, work-area splits, rotation patterns) are owned by MDS and pulled into FDS on a monthly bulk cadence with on-demand deltas. FDS authoritatively derives plans from this master data; any operational variance is captured as a tracked, auditable adjustment rather than a redefinition of the duty. Additionally, FDS allows ad hoc overtime planning.

4.3. Plan vs. scan reconciliation as the canonical pay-validation pattern

Pay-affecting decisions (OT and Schedule-Attendance approval) cross-reference the approved plan against PDA and Console scan events. The plan is the authoritative reference for downstream timesheet validation; manual override is permitted but always logged.

4.4. Event-driven, API-led integration

High-volume, low-latency flows (scan events and PSP OT flow) use the IBM MQ. Lower-volume flows (Joined up and People app) use synchronous APIs through the BIG API gateway. Bulk analytics flows to the Data Platform use the Batch data export. No point-to-point integration is introduced.

How do these decisions satisfy the quality goals

Quality Goal	Strategy that delivers it
Auditability & Traceability	Immutable event-sourced audit log on every approval/rejection/adjustment of OT Plan and timesheet
Pay Accuracy	Plan-vs-scan reconciliation (4.3) is the single approved path to pay; manual overrides logged.
Operational Availability	Reuse of the proven FDS platform (4.1); horizontally scalable web/app tier
Integration Reliability	Event-driven + API-led pattern with at-least-once semantics,
Usability	Reuse (4.1) of an established UX, with Processing-specific screens layered on familiar navigation.

5. Building Block View

Content

The building block view shows the static decomposition of the system into building blocks (modules, components, subsystems, classes, interfaces, packages, libraries, frameworks, layers, partitions, tiers, functions, macros, operations, data structures, ...) as well as their dependencies (relationships, associations, ...)



This view is mandatory for every architecture documentation. In analogy to a house this is the **Floor Plan**.

Since it contains static view of the system, we need to put container and component diagrams (C2 & C3) from C4 model. It only shows the relationships between various containers, components and external systems (Both internal & external to RMG)

This section should also contain Integration Architecture (Reference to ICDs etc.)

Motivation

Maintain an overview of your source code by making its structure understandable through abstraction.

This allows you to communicate with your stakeholder on an abstract level without disclosing implementation details.

Further Information

See [Building Block View](#) in the arc42 documentation.

Royal Mail FDS - Processing Sites: Worked Example

5.1. Container Diagram

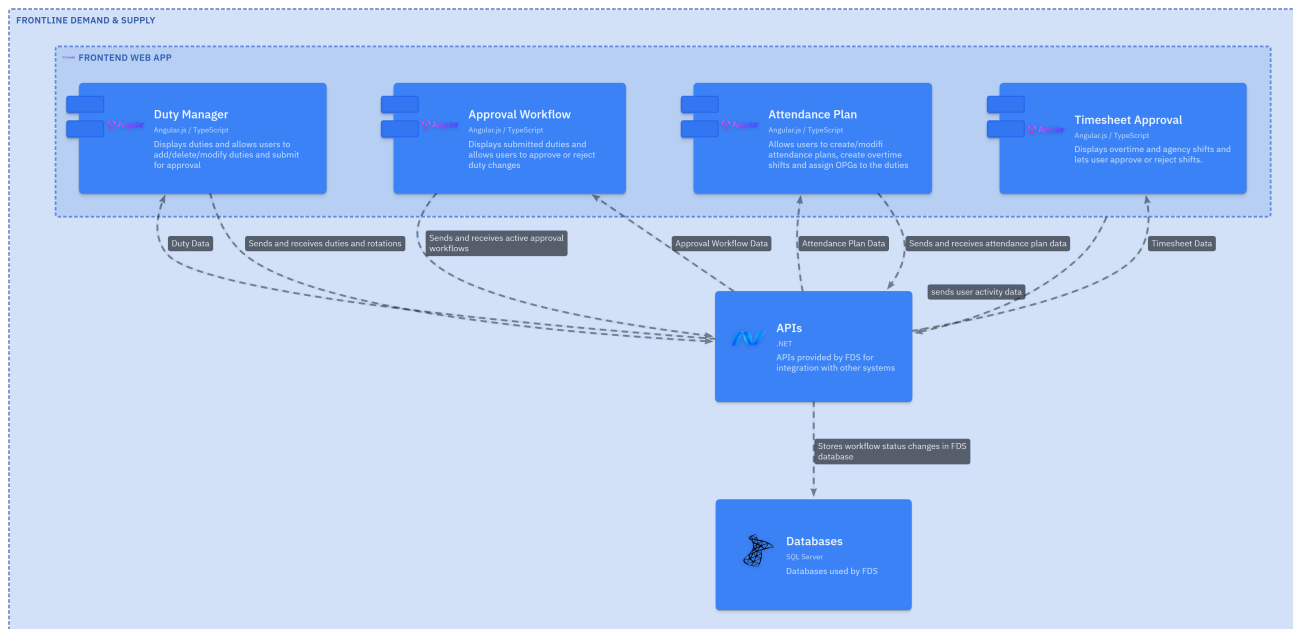


Figure 5. Component Diagram (Frontend Component)

6. Runtime View

Contents

The runtime view describes concrete behavior and interactions of the system's building blocks in form of scenarios from the following areas:

- important use cases or features: how do building blocks execute them?
- interactions at critical external interfaces: how do building blocks cooperate with users and neighboring systems?
- operation and administration: launch, start-up, stop
- error and exception scenarios



The main criterion for the choice of possible scenarios (sequences, workflows) is their **architectural relevance**. It is **not** important to describe a large number of scenarios. You should rather document a representative selection.

Motivation

You should understand how (instances of) building blocks of your system perform their job and communicate at runtime. You will mainly capture scenarios in your documentation to communicate your architecture to stakeholders that are less willing or able to read and understand the static models (building block view, deployment view).

Form

Following diagrams could be part of this section:

- **System Landscape Diagram (C4 Model)**
- **Activity Diagrams and Sequence Diagrams for some of the key Use Cases**

Further Information

See [Runtime View](#) in the arc42 documentation.

Royal Mail FDS - Processing Sites: Worked Example

6.1. Use Case 01 – Approve Overtime

Trigger: Manager Approve action on the FDS Over time timesheet screen

1. Delivery Office Manager (COM) opens the Timesheet Screen
2. Frontend → Backend → Timesheet Service API → FDS DB (fetch unapproved shifts)
3. Manager approves shifts
4. Timesheet Service publishes to IBM MQ topic "approved-shifts"
5. Parallel consumption: PSP (SAP) + Data Platform both subscribe from MQ

- ### 6.1.1. Activity Diagram – Approve Overtime



6.1.2. Sequence Diagram – Approve Overtime



7. Deployment View

Content

The deployment view describes:

1. technical infrastructure used to execute your system, with infrastructure elements like geographical locations, environments, computers, processors, channels and net topologies as well as other infrastructure elements and
2. mapping of (software) building blocks to that infrastructure elements.

Often systems are executed in different environments, e.g. development environment, test environment, production environment. In such cases you should document all relevant environments.

Especially document a deployment view if your software is executed as distributed system with more than one computer, processor, server or container or when you design and construct your own hardware processors and chips.

From a software perspective it is sufficient to capture only those elements of an infrastructure that are needed to show a deployment of your building blocks. Hardware architects can go beyond that and describe an infrastructure to any level of detail they need to capture.



This section is split into two: **Deployment View (This Section)** and **Cloud Architecture (Section 8)**

Motivation

Software does not run without hardware. This underlying infrastructure can and will influence a system and/or some cross-cutting concepts. Therefore, there is a need to know the infrastructure.

Form

This section and section 8 should contain Deployment and Integration diagrams. We need to provide Azure deployment diagrams for applications deployed in Azure cloud mapping individual components to Azure services and network topologies. It should also highlight Azure regions, Availability Zones for both Prod and DR (Pre-Prod)

Further Information

See [Deployment View](#) in the arc42 documentation.

Royal Mail FDS - Processing Sites: Worked Example

7.3. Infrastructure Level 1 - Production topology

Mapping of building blocks to infrastructure (production):

Tier	Components	Building blocks hosted
Edge		Public ingress for web shell (BB12) and partner APIs (BB9).
Web tier	Angular App	BB12 web shell.
Application tier	Containerised microservices (AKS) behind internal load-balancer.	BB1, BB2, BB3, BB4, BB5, BB6, BB7, BB8, BB10.
Integration tier	API Gateway + SSIS + AMQP	BB9. Bridges to PSP, JoinedUp, MDS, PDA, Console.
Data tier	Managed relational store (SQL Server)	BB1–BB8 persistence; BB11 audit.
Analytics export	Scheduled extract jobs using SSIS	BB6 reporting outputs.
Identity	AD + Conditional Access.	BB10.
Observability	Centralised structured logs, metrics	BB11 + platform-wide.

Quality and performance features:

- Active/active across two UK Atos data centres for the application and integration tiers; database with synchronous geo-replication.
- RPO $\leq$ 15 minutes, RTO $\leq$ 4 hours for the full service; payroll-egress queues are durable and replayable.
- All inter-tier traffic on private networking; no public ingress to the application tier.

8. Cloud Architecture

Cloud Infrastructure section should contain cloud architecture diagram highlighting network topology, subnet, firewalls and cloud services used by the architecture. It should also provide information around high availability, regions, subscriptions, SKUs, Network Security Groups, NSG Rules, Firewalls, Cloud patterns and Cost optimization

Availability NFR: **This needs to be considered when detailing the Regional/AZ placement**

NFRID	Requirement Description	Status
NFAV001	The FDS solution shall be available for use and supported 24 hours a day, 7 days a week, 365 days a year in adherence with the technical design principles and standards applicable to Service Criticality Level 1. As a mission-critical system supporting the payment of Variable Pay Hours(over time), unplanned unavailability is not acceptable, and any failure must be recovered within a maximum Recovery Time Objective of 24 hours(TBC with service). The solution may only be taken offline outside of this commitment during a planned maintenance window, agreed in advance with the Application Service Manager, who shall notify the user community prior to any scheduled downtime.	Approved

8.1. Regions



Capture the Azure regions used for the solution.

Region	Primary	Secondary	Availability Zones		
			AZ1	AZ2	AZ3
North Europe	Yes				
West Europe					
UK South					
Germany West Central	Yes		Yes	Yes	Yes
Sweden Central		Yes	Yes	Yes	Yes

8.1.1. Rationale (latency, regulatory, capacity constraints)

- Capacity constraints across the North Europe and West Europe regions are currently impeding the provisioning of the SQL Managed Instance (MI), rendering deployment unfeasible in these locations.
- The Dev, SIT, and QA environments have already been instantiated in the North Europe region

and will remain there, with no further relocation envisaged.

- In alignment with Microsoft's recommendation, the Pre-Production and Production environments will be migrated to Germany West Central (designated as the Primary region) and Sweden Central (configured as the Warm Standby for Disaster Recovery).

8.2. Availability Zones



Define high availability architecture.

- Services deployed across zones
- Zone pinning requirements (if any)
- Zonal vs zone-redundant SKUs

Example 1. High Availability Architecture

Example:

- Region supports 3 AZs
 - Workloads deployed Zone-Redundant (ZRS / AZ-aware)
-
- Region: FDS Prod and Prod Application are deployed in the Germany West and Sweden Central regions, each supporting 3 AZs.
 - App Service plans

8.3. Subscriptions (Naming & Structure)



Aligned to the **subscription factory model** from your HLD artefact

Details to include:

- Subscription names (fully qualified)
- Environment split:
 - Prod
 - Pre-Prod
 - Non-Prod (Dev/Test)
- Platform vs Workload subscriptions
- Naming standard compliance

Env	Subscription Name	Subscription ID	Type
Dev	rm-artfds-slz-d-sub-01	039fe12a-dcea-4087-9431-c2ed92e61917	FDS Workload Subscription

Env	Subscription Name	Subscription ID	Type
QA	rm-artfds-slz-n-sub-01	23b1a3cd-0e03-4852-aa04-bad88fd77c6b	FDS Workload Subscription
SIT	rm-artfds-slz-a-sub-01	5c247745-b158-4c53-9cf2-13d52dd46ad9	FDS Workload Subscription
PreProd	rm-artfds-slz-v-sub-01	23a01b16-0f01-46b3-aad0-d2e95c1441e4	FDS Workload Subscription
Prod	rm-artfds-slz-p-sub-01	1f7b29ec-d1e9-40fc-a861-39d60ce2949b	FDS Workload Subscription

Standards

8.4. SKU'S Used (Per Region)



Define all critical service SKUs per region.

Details to include:

- Compute SKUs (VM sizes / VMSS)
- Storage SKUs (Standard / Premium / ZRS)
- PaaS SKUs (if applicable)

Example 2. SKU Example

Example:

ENVIRONMENT	COMPONENT	REGION	SKU
NPD	ExpressRoute GW	UK South	ErGw3AZ
PPD	Firewall	UK South	Premium
PRD	VM	UK South	D4s v5

ENV	Name	Component	Region	SKU
SIT	rm-ne-artfds-sit-asp-01	App Service plan	northeurope	P1v3 (PremiumV3)
SIT	rm-ne-artfds-sit-asp-02	App Service plan	northeurope	P2v3 (PremiumV3)
SIT	rm-ne-artfds-sit-funcasp-01	App Service plan	northeurope	EP1 (ElasticPremium)
SIT	rm-ne-artfds-sit-logicasp-01	App Service plan	northeurope	WS1 (WorkflowStandard)
SIT	rm-ne-artfds-sit-appgw	Application gateway	northeurope	WAF_v2

ENV	Name	Component	Region	SKU
SIT	rm-ne-artfds-sit-redis01	Azure Cache for Redis	northeurope	Premium
SIT	disk1	Disk	northeurope	StandardSSD_LRS (Standard)
SIT	disk2	Disk	northeurope	StandardSSD_LRS (Standard)
SIT	rm-ne-artfds-sit-vm01-osdisk	Disk	northeurope	Premium_LRS (Premium)
SIT	rm-ne-artfds-sit-vm02-osdisk	Disk	northeurope	Premium_LRS (Premium)
SIT	rm-ne-artfds-sit-vm03-osdisk	Disk	northeurope	Premium_LRS (Premium)
SIT	rm-nefdssitAgnt01_OsDisk_1_5806e1fabcf4a2ead4024fcb6640f81	Disk	northeurope	Premium_LRS (Premium)
SIT	rm-ne-artfds-sit-evnthubns-01	Event Hubs Namespace	northeurope	Standard (Standard)
SIT	rm-ne-artfds-sit-kv-01	Key vault	northeurope	standard
SIT	rm-ne-artfds-sit-law-workspace01	Log Analytics workspace	northeurope	PerGB2018
SIT	rm-ne-artfds-sit-appgw-pip	Public IP address	northeurope	Standard (Regional)
SIT	rmg-ne-artfds-sit-sqlmi-01	SQL managed instance	northeurope	GP_Gen5 (GeneralPurpose)
SIT	rmneartfidsagncshftdt01	Storage account	northeurope	Standard_LRS (Standard)
SIT	rmneartfidsagnctmshrpt01	Storage account	northeurope	Standard_LRS (Standard)
SIT	rmneartfidsarplan01	Storage account	northeurope	Standard_LRS (Standard)
SIT	rmneartfidsarrepo01	Storage account	northeurope	Standard_LRS (Standard)
SIT	rmneartfidsfleet01	Storage account	northeurope	Standard_LRS (Standard)
SIT	rmneartfidslegacyrt01	Storage account	northeurope	Standard_LRS (Standard)
SIT	rmneartfidsmd01	Storage account	northeurope	Standard_LRS (Standard)

ENV	Name	Component	Region	SKU
SIT	rmneartfdsmmdmdata01	Storage account	northeurope	Standard_LRS (Standard)
SIT	rmneartfdsovrtnmrpt01	Storage account	northeurope	Standard_LRS (Standard)
SIT	rmneartfdsrcstodp01	Storage account	northeurope	Standard_LRS (Standard)
SIT	rmneartfdrdmref01	Storage account	northeurope	Standard_LRS (Standard)
SIT	rmneartfdssitsabkend01	Storage account	northeurope	Standard_RAGRS (Standard)
SIT	rmneartfdssitsacustm01	Storage account	northeurope	Standard_LRS (Standard)
SIT	rmneartfdssitsafn01	Storage account	northeurope	Standard_LRS (Standard)
SIT	rmneartfdssitsalg01	Storage account	northeurope	Standard_ZRS (Standard)
SIT	rmneartfdssitsasql01	Storage account	northeurope	Standard_LRS (Standard)
SIT	rmneartfdssitwinpak01	Storage account	northeurope	Standard_LRS (Standard)
QA	rm-ne-artfds-npd-asp-01	App Service plan	northeurope	P1v3 (PremiumV3)
QA	rm-ne-artfds-npd-asp-02	App Service plan	northeurope	P2v3 (PremiumV3)
QA	rm-ne-artfds-npd-funcasp-01	App Service plan	northeurope	EP1 (ElasticPremium)
QA	rm-ne-artfds-npd-logicasp-01	App Service plan	northeurope	WS1 (WorkflowStandard)
QA	rm-ne-artfds-npd-appgw	Application gateway	northeurope	WAF_v2
QA	data	Disk	northeurope	Premium_LRS (Premium)
QA	data1	Disk	northeurope	Premium_LRS (Premium)
QA	data2	Disk	northeurope	StandardSSD_LRS (Standard)
QA	rm-ne-artfds-npd-vm01-osdisk	Disk	northeurope	Premium_LRS (Premium)
QA	rm-ne-artfds-npd-vm2-osdisk	Disk	northeurope	Premium_LRS (Premium)

ENV	Name	Component	Region	SKU
QA	rm-ne-artfds-npd-vm3-osdisk	Disk	northeurope	Premium_LRS (Premium)
QA	rm-ne-artfds-npd-vm4-osdisk	Disk	northeurope	Premium_LRS (Premium)
QA	rm-ne-artfds-npd-evnthubns-01	Event Hubs Namespace	northeurope	Standard (Standard)
QA	rm-ne-artfds-npd-kv-01	Key vault	northeurope	standard
QA	rm-ne-artfds-npd-law-workspace01	Log Analytics workspace	northeurope	PerGB2018
QA	rm-ne-artfds-npd-appgw-pip	Public IP address	northeurope	Standard (Regional)
QA	vault-mkmjc9ro	Recovery Services vault	northeurope	RS0 (Standard)
QA	rmg-ne-artfds-npd-sqlmi1-01	SQL managed instance	northeurope	GP_Gen5 (GeneralPurpose)
QA	rmneartfdnpdsovrtrmrpt01	Storage account	northeurope	Standard_LRS (Standard)
QA	rmneartfdsnpdagshftdt01	Storage account	northeurope	Standard_LRS (Standard)
QA	rmneartfdsnpdagtmshrp01	Storage account	northeurope	Standard_LRS (Standard)
QA	rmneartfdsnpdarplan01	Storage account	northeurope	Standard_LRS (Standard)
QA	rmneartfdsnpdarrepto01	Storage account	northeurope	Standard_LRS (Standard)
QA	rmneartfdsnpdfleet01	Storage account	northeurope	Standard_LRS (Standard)
QA	rmneartfdsnpdlegacyrt01	Storage account	northeurope	Standard_LRS (Standard)
QA	rmneartfdsnpdmd01	Storage account	northeurope	Standard_LRS (Standard)
QA	rmneartfdsnpdmdmddata01	Storage account	northeurope	Standard_LRS (Standard)
QA	rmneartfdsnpdrcstodp01	Storage account	northeurope	Standard_LRS (Standard)
QA	rmneartfdsnpdrdmref01	Storage account	northeurope	Standard_LRS (Standard)
QA	rmneartfdsnpdsafn01	Storage account	northeurope	Standard_LRS (Standard)

ENV	Name	Component	Region	SKU
QA	rmneartfdsnpsalg01	Storage account	northeurope	Standard_LRS (Standard)
QA	rmneartfdsnpsasql01	Storage account	northeurope	Standard_LRS (Standard)
QA	rmneartfdsnpsawa01	Storage account	northeurope	Standard_LRS (Standard)
QA	rmneartfdsnpdwinpak01	Storage account	northeurope	Standard_LRS (Standard)
QA	stdevtestmigration3434	Storage account	northeurope	Standard_LRS (Standard)
QA	sttfbackendulubfl	Storage account	northeurope	Standard_LRS (Standard)
QA	SecurityInsights(rm-ne-artfds-npd-law-workspace01)	microsoft.operations management/solutions	northeurope	Unified
Dev	rm-ne-artfds-dev-asp-01	App Service plan	northeurope	P1v3 (PremiumV3)
Dev	rm-ne-artfds-dev-asp-02	App Service plan	northeurope	P2v3 (PremiumV3)
Dev	rm-ne-artfds-dev-funcasp-01	App Service plan	northeurope	EP1 (ElasticPremium)
Dev	rm-ne-artfds-dev-logicasp-01	App Service plan	northeurope	WS1 (WorkflowStandard)
Dev	rm-ne-artfds-dev-appgw	Application gateway	northeurope	WAF_v2
Dev	rm-ne-artfds-dev-redis01	Azure Cache for Redis	northeurope	Premium
Dev	rm-ne-artfds-dev-vm01-osdisk	Disk	northeurope	Premium_LRS (Premium)
Dev	rm-ne-artfds-dev-vm02-osdisk	Disk	northeurope	Premium_LRS (Premium)
Dev	rm-nefdsdevAgnt01_OsDisk_1_85b9c256dacd4cdf97cf72aeda2d411d	Disk	northeurope	Premium_LRS (Premium)
Dev	rm-ne-artfds-dev-evnthubns-01	Event Hubs Namespace	northeurope	Standard (Standard)
Dev	rm-ne-artfds-dev-kv-01	Key vault	northeurope	standard
Dev	rm-ne-artfds-dev-law-workspace01	Log Analytics workspace	northeurope	PerGB2018

ENV	Name	Component	Region	SKU
Dev	rm-ne-artfds-dev-appgw-pip	Public IP address	northeurope	Standard (Regional)
Dev	rmg-ne-artfds-dev-sqlmi-01	SQL managed instance	northeurope	GP_Gen5 (GeneralPurpose)
Dev	rmneartfdsdevsabkend01	Storage account	northeurope	Standard_RAGRS (Standard)
Dev	rmneartfdsdevsacustm01	Storage account	northeurope	Standard_LRS (Standard)
Dev	rmneartfdsdevsafn01	Storage account	northeurope	Standard_LRS (Standard)
Dev	rmneartfdsdevsalg01	Storage account	northeurope	Standard_LRS (Standard)
Dev	rmneartfdsdevsasql01	Storage account	northeurope	Standard_LRS (Standard)
Dev	rmneartfdsdevsawa01	Storage account	northeurope	Standard_LRS (Standard)
Dev	SecurityInsights(rm-ne-artfds-dev-law-workspace01)	microsoft.operations management/solutions	northeurope	Unified

8.5. Network Security Group (NSG) Rules



Already aligned to your HLD approach, where NSGs control **spoke traffic**

Details to capture:

- Source → Destination
- Port / Protocol
- Action (Allow/Deny)
- Priority
- Purpose

Example 3. NSG Rules

Example table:

RULE NAME	SOURCE	DESTINATION	PORT	ACTION	PURPOSE
Allow-App-To-DB	App Subnet	DB Subnet	1433	Allow	SQL access
Allow-App-To-Blob	App Subnet	Storage Subnet	443	Allow	Blob Access



If traffic stays **inside the VNet** → **NSG rules must be defined**



If traffic leaves the VNet → **NSGs are not the primary control** (handled via hub firewall(s))

TRAFFIC TYPE	NSG REQUIRED	NOTE
Subnet → Subnet (same VNet)	☐ Yes	Primary control
VNet → External / Internet	☐ No	Controlled by firewall/routing
VNet → Other VNet	☐ No	Controlled via peering + firewall

8.6. Firewall Rules (North-South / East-West)

Details to include:

- DNAT / SNAT rules
- Application rules (FQDN-based)
- Network rules (IP-based)
- Inbound vs outbound distinction

Example 4. Firewall Rules

Example:

RULE TYPE	FROM	TO	PORT	ACTION
DNAT	Internet	Web Tier	443	Allow
Network	App Subnet	External API	443	Allow

8.7. Network / Subnet Design



Critical for addressing your “network/subnet size”.

Details to include:

- VNET address space
- Subnet segmentation
- CIDR sizing
- Reserved IP strategy
- Growth headroom

Example:

SUBNET	CIDR	PURPOSE
AzureFirewallSubnet	/26	Firewall
AppSubnet	/24	App tier
DBSubnet	/24	Database

8.8. Patterns / Blueprints / Catalogue of Whitelisted Azure Products/Services

Pattern Consumption Table



The architect **MUST** confirm coverage across all domains:

DOMAIN	PATTERN IDENTIFIED (Y/N)	NOTES
Networking		
Security		
Compute		
Data		
Integration		

Catalogue

8.9. Cost Optimisation and FinOps Alignment*

- Use of reserved capacity (where applicable)
- Right-sizing of compute resources
- Use of PaaS over IaaS where appropriate
- Separation of environments for cost control
- Costs **MUST** be derived from the Azure Calculator
- DR costs **MUST** be included where applicable

Cost Breakdown Table

Example 6. Cost Breakdown

Example:

COMPONENT	SERVICE	SKU	REGION	EST. MONTHLY COST (£)	JUSTIFICATION
Compute	VMSS	D4s v5	UK South		Supports app tier scaling
Security	Azure Firewall	Premium	UK South		Required for central control
Data	Azure SQL	Business Critical	UK South		

9. Security Architecture

Content

Software security architecture is the foundational design of a system that embeds defenses directly into the code and infrastructure, ensuring resistance against malicious attacks. It is a critical necessity to proactively mitigate vulnerabilities, prevent catastrophic data breaches, and maintain customer trust

A robust software security architecture is essential for several key reasons:

- **Proactive Vulnerability Mitigation:** *By designing security into the software development life cycle (SDLC) from the ground up, you can prevent up to 80% of security problems before the code is even written. It replaces reactive, "afterthought" patching with built-in resilience.*
- **Minimizing Breach Impact:** *A solid architecture ensures that if a component is breached, the damage is isolated. Principles like "least privilege" and strict access controls prevent an attacker from escalating their access across the entire system.*
- **Protecting Critical Assets:** *It establishes standardized encryption, authentication, and authorization checkpoints to safeguard sensitive user data, intellectual property, and financial systems.*
- **Ensuring Compliance:** *For highly regulated industries like finance, healthcare, and e-commerce, a structured architectural framework is required to meet strict legal regulations and data protection laws*

It should contain the following:

1. Cyber Architecture ARB Survey
2. Data Flow Diagram with STRIDE Threat Model and Mitigation
3. Identity & Access Management (IAM)
4. Data Categorization
5. Usage of AI (If Applicable)
6. Security RAID Log
7. Application Business Criticality Rating
8. Quantum Cryptography Secure (TBC)
9. Active Directory Tier Level (TBC)
10. Privileged Access Requirements (CyberArk)
11. User Provisioning Requirement (SailPoint)
12. Key Management Services Requirements

Motivation

The primary rationale for software security architecture is to proactively embed protective measures into a system, rather than treating them as an afterthought. It acts as a foundational blueprint that

minimizes the attack surface, prevents costly architectural reworks, and ensures business-wide compliance.

The fundamental drivers and objectives of this architecture include:

1. The Secure by Design Imperative

- a. **Shift-Left Approach:** *Embedding security during the initial planning and design phases is exponentially more cost-effective than remediating vulnerabilities found in production.*
- b. **Complexity Management:** *Modern software relies heavily on distributed systems and APIs. Security architecture provides consistent, unified controls rather than fragmented, bolt-on solutions that leave systems fragile.*

2. Core Protection Objectives (CIA Triad)

- a. **Confidentiality:** *Ensures that sensitive data is protected from unauthorized access, leveraging end-to-end encryption and robust identity access management (IAM).*
- b. **Integrity:** *Maintains the accuracy and trustworthiness of data by implementing strict authorization protocols and data classification policies.*
- c. **Availability:** *Ensures services and data remain accessible, even amidst malicious disruptions or unintended software failures*

3. Structural Capabilities

- a. **Segregation & Segmentation:** *Hybrid and cloud environments require independent building blocks so that a compromise in one service does not cascade through the entire organization.*
- b. **Zero-Trust Frameworks:** *Assumes no user or service is trusted by default. Architecture mandates continuous validation, authentication, and authorization.*

4. Business Enablement and Risk Management

- a. **Compliance:** *Aligns system designs with data privacy and cybersecurity laws, such as GDPR and other industry frameworks.*
- b. **Cost Reduction:** *Minimizes long-term expenses by preventing security breaches, reducing expensive downtime, and streamlining incident response.*

Form

Security Architecture can be documented through diagrams, text and tables. This section should contain at least a Level-1 DFD along with a STRIDE Threat Model with clearly defined threat boundaries. RAID Logs should be in tabular format.

9.1. Cyber Architecture Standards and NFRs

Table 1. Details

Title	Response
All Royal Mail Cyber Architecture Standards can be found here: Architecture Standards Please confirm that you have reviewed these standards before completing the survey.	Yes/No
TDA Submission Name	
TDA Approval Date Required	
Cyber Advisor Name (A Cyber Advisor is required for every project going through TDA)	
Does this TDA submission introduce any AI? Please detail the requirement.	
Data Privacy Impact Assessment Reference Number (if required)	

Table 2. Cyber Architecture Standards Attestation

Survey Question	Response (Yes/No/NA)	Rationale (If No or NA)
TDA Q1 - Does the solution make use of cloud-based services and ensure that they are appropriately secured and managed inline with ISS-001 - Cloud Computing Security Standard?		
TDA Q2 - Does the solution transfer and store data, if so have you established and documented a minimum acceptable level of cryptographic algorithms and protocols for transmission and storage of Royal Mail data inline with ISS-002 - Cryptography Standard?		

TDA Q3 - Has the solution been designed with the key objectives of protection of data and disaster recovery/business continuity with the ability to recover systems and recent live data in the event of a partial or total loss of a service aligned to ISS-003 - Data Backup and Restoration Standard?		
TDA Q4 -Does the solution ensure that RM assets are appropriately managed and protected from information security breaches inline with ISS-004 - Asset Management Standard?(An Information Asset is a definable piece of information, stored or processed in any manner which is recognized as valuable to the Royal Mail Group. A system that processes that information is also an asset.)		
TDA Q5 - Does the solution required and meet the classifying of information assets as stated in ISS-005 - Information Classification Standard?		
TDA Q6 - Has the solution/design assigned Data/System Impact Levels as stated in ISS-005 - Information Classification Standard?		
TDA Q7 - Does the solution/design require and ensure that data is labelled accordingly as stated in ISS-005 - Information Classification Standard?		
TDA Q 8 - Has the solution or design identified, assessed and provided a treatment plan and monitoring of any Tech and Cyber risk as detailed in ISS-007 - Risk Management Standard?		

TDA Q9 - Has the solution implemented the identified requirements for the provisioning, secure usage, and management of company-provided mobile devices, specifically tablets and smartphones, through the use of Mobile Device Management (MDM) software aligned to ISS-008 - Mobile Security Standard?		
TDA Q10 - Has the solution met the requirements to protect RMG data specifically confidential or strictly confidential data accessed or stored on mobile devices as outlined in ISS-008 - Mobile Security Standard?		
TDA Q11 - Does the solution implement computer network solutions in accordance with the "Information Security requirements" specified in ISS-009 - Network Security Standard?		
TDA Q12 - Has the project understood the procedures necessary to identify, assess, prioritise, and remediate vulnerabilities affecting Royal Mail Group (RMG) following the ISS-010 - Vulnerability Management Standard?(Including but not limited to operating systems, applications, cloud resources, web technologies, server, desktop, mobile device software, hardware, network devices and common coding vulnerabilities in software-development processes)		
TDA Q13 - Has the solution/project reviewed and aligned to the security requirements for developing and using web services, whether in designing a solution, implementing a system or operating a system based on web services in line with ISS-011 - Web Services Security Standard		

TDA Q14 - Does the solution or design implement endpoint solutions in accordance with requirements from Information Security and others; to describe system functionality and parameters necessary to fulfil security requirements; and to define key support processes as specified in ISS-012 - Endpoint Security Standard?		
TDA Q15 - Does the solution or design meet the minimum standard to allow Royal Mail Group (RMG) to address Authentication related risks through the implementation of controls as specified in ISS-013 - Authentication Standard?		
TDA Q16 - Does the solution need to authenticate non-RMG users and is this inline with ISS-013 - Authentication Standard?		
TDA Q17 - Does the solution need to authenticate users from an RMG-managed user directory and does this follow the requirements in ISS-013 - Authentication Standard?		
TDA Q18 - Does the proposed design/solution meet the security requirements to ensure that software development by/on behalf of Royal Mail Group (RMG) minimizes and prevents the risk/impact of information security following ISS-014 - Secure Product Development Standard		
TDA Q19 - Does the design/solution follow the defined set of requirements for security testing providing confirmation that all RMG systems and processes are sufficiently resilient in line with RMG risk appetite, with all controls proven effective as outlined in ISS-015 - Cyber Security Testing Standard?		

TDA Q20 - Have all individuals working on this design/project for Royal Mail Group Ltd, including employees, workers, self-employed contractors, consultants, and agency workers (referred to as “our people”) completed the required cybersecurity training and awareness defined in ISS-016 - Cyber Security Training and Awareness Standard?		
TDA Q21 - Does the design/project follow the secure practices to manage secrets and cryptographic keys following ISS-017 - Secret & Key Management Standard alongside ISS-002 - Cryptography Standard which defines the acceptable cryptographic algorithms and protocols for the secure transmission and storage of data?		
TDA Q22 - Has the design/project determined what software needs to be installed and minimum logging level for Syslog, Common Event Format (CEF) logs and Windows events to maintain visibility across the Royal Mail’s infrastructure. Application logs are based on use case and will be assessed by the Cyber Engineering team using requirements/tools available. i.e Data connector/Logic App etc in line with ISS-020 - SIEM System Monitoring Standard?		
TDA Q23 - Does this design/project meet the requirements for Royal Mail Group (RMG) Cyber Threat Intelligence (CTI) programme and have these been aligned to ISS-023 - Threat Intelligence Standard?		

Table 3. Cyber Architecture Standards-Aligned NFRs

ID	Category	Requirement	Standards Reference	SaaS	PaaS	IaaS	OnPrem
2	Access Reviews & Logging	Expose role and membership information in a way that central access review/governance tools can consume (e.g. via IdP groups or IGA).	ISS-013 - Authentication Standard 4.4.2	Y	Y	Y	Y
3	Access Reviews & Logging	Support periodic access reviews of privileged roles with exportable reports and clearly identifiable role owners.	POL-003 - Identity and Access Management Policy 4.9.2	Y	Y	Y	Y
4	Access Reviews & Logging	Log every access change (role assignment, elevation, delegation) with actor, subject, time, and action, and send to central logging.	ISS-009 - Network Security Standard 8.3.17	Y	Y	Y	Y
5	Access Reviews & Logging	Record and retain privileged administrative sessions (session recording/command logging) for high-tier systems, or implement compensating controls (detailed audit logs + strong change control) where session recording is infeasible.	ISS-009 - Network Security Standard 10.1.9	Y	Y	Y	Y
6	Account Lifecycle	Map application roles to IdP groups or attributes so that joiners, movers, and leavers are handled centrally; avoid manual creation of standard user accounts.	POL-003 - Identity and Access Management Policy 4.2.8	Y	Y	Y	Y
7	Account Lifecycle	Ensure any local accounts that cannot be federated have an explicit owner, justification, and expiry date.	ISS-013 - Authentication Standard 4.1.8	Y	Y	Y	Y
8	Account Lifecycle	Trigger deprovisioning of application accounts automatically when the identity is disabled in the IdP.	POL-003 - Identity and Access Management Policy 4.11.1	Y	Y	Y	Y

ID	Category	Requirement	Standards Reference	SaaS	PaaS	IaaS	OnPrem
9	Account Lifecycle	Prohibit shared credentials for human users; any unavoidable exceptions must have formal approval and monitoring.	ISS-013 - Authentication Standard 4.2.9	Y	Y	Y	Y
10	Account Recovery & Self-Service	Delegate password reset, MFA reset, and account recovery to the central IdP; do not implement separate self-service flows.	ISS-013 - Authentication Standard 4.2.8	Y	Y	Y	Y
11	Account Recovery & Self-Service	Where separate account unlock or recovery flows exist (e.g. local admin accounts), ensure they are strongly authenticated, logged, and tightly controlled.	POL-003 - Identity and Access Management Policy 4.10.9	Y	Y	Y	Y
12	Applications (PaaS)	Ensure all managed runtimes (web apps, functions, containers, integration services) run on supported versions and define a cadence for runtime upgrades.	ISS-011 - Web Services Security Standard 4.7		Y	Y	Y
13	Applications (PaaS)	Instrument application code with structured logging, metrics, and traces and connect them to central monitoring and SIEM.	ISS-011 - Web Services Security Standard 3.10		Y	Y	Y
14	Applications (PaaS)	Configure platform features securely by disabling sample apps, management consoles, or remote debugging in production and locking down console endpoints.	ISS-011 - Web Services Security Standard 4.10		Y	Y	Y

ID	Category	Requirement	Standards Reference	SaaS	PaaS	IaaS	OnPrem
15	Applications (PaaS)	Store application configuration in an approved configuration store and store secrets only in the central secrets manager/platform key vault; prohibit secrets in code, images, or plaintext environment variables and enforce detection (secret scanning) in CI/CD.	ISS-014 - Secure Product Development Standard 4.11		Y	Y	Y
16	Applications (PaaS)	Enable PaaS threat protection features for sensitive services (e.g. DB threat detection, storage anomaly detection) and route alerts into central incident handling.	ISS-001 - Cloud Computing Standard 4.3.1		Y	Y	Y
17	Authentication Model	Rely on central IdP/SSO for MFA, password policy, and basic login security.	ISS-013 - Authentication Standard 4.1.9	Y	Y	Y	Y
18	Authentication Model	Use RMG-approved SSO/IdP for all human user authentication and do not implement a separate username/password store.	ISS-013 - Authentication Standard 4.1.9	Y	Y	Y	Y
19	Authentication Model	Do not implement custom MFA; rely on IdP-provided MFA and conditional access policies.	POL-003 - Identity and Access Management Policy 4.6.5	Y	Y	Y	Y
20	Authentication Model	Ensure all externally exposed endpoints are protected with authentication unless explicitly approved as public/anonymous.	ISS-013 - Authentication Standard 4.1.15	Y	Y	Y	Y
21	Backups & Recovery	Protect on-prem backups against theft and ransomware using offsite copies, immutable storage, or tape vaulting and test restore capability regularly.	ISS-003 - Data Backup and Restoration Standard 4.1.5				Y

ID	Category	Requirement	Standards Reference	SaaS	PaaS	IaaS	OnPrem
22	Backups & Recovery	Ensure on-prem infrastructure is fully represented in business continuity and disaster recovery plans, including RTO/RPO and prioritisation of systems during recovery.	ISS-001 - Cloud Computing Standard 6				Y
23	Backups & Recovery	Ensure critical data stores are covered by central backup solutions where they exist, or implement backups if not.	ISS-001 - Cloud Computing Standard 6.1	Y	Y	Y	Y
24	Backups & Recovery	Define RPO/RTO for each data store and validate that backup and restore processes meet those objectives.	ISS-003 - Data Backup and Restoration Standard 4	Y	Y	Y	Y
25	Backups & Recovery	Perform and evidence periodic restore tests from backups for critical systems.	ISS-003 - Data Backup and Restoration Standard 4.1.5	Y	Y	Y	Y
26	Business Continuity & Resilience	Define what degraded but safe operation looks like under attack or component failures (e.g. rate limiting, read-only mode).	ISS-006 - Incident Management Standard 2.3.3	Y	Y	Y	Y
27	Business Continuity & Resilience	Ensure failover and disaster recovery mechanisms do not bypass security controls and maintain consistent auth/authorisation.	ISS-001 - Cloud Computing Standard 6	Y	Y	Y	Y
28	Business Continuity & Resilience	Test failover and disaster recovery at agreed intervals and document any security-relevant findings.	ISS-001 - Cloud Computing Standard 6	Y	Y	Y	Y
29	Client Access & Device Posture	Rely on centrally managed corporate device security (OS hardening, EDR, MDM) where applicable.	ISS-008 - Mobile Security Standard 4.2.1	Y	Y	Y	Y

ID	Category	Requirement	Standards Reference	SaaS	PaaS	IaaS	OnPrem
30	Client Access & Device Posture	Ensure administrative access to management consoles and privileged portals is only possible from managed endpoints using device-based policies, IP allow-lists, or conditional access.	ISS-012 - Endpoint Security Standard 4.2.2	Y	Y	Y	Y
31	Client Access & Device Posture	Ensure user-facing applications handling sensitive data can be constrained to managed devices using RMGal device posture policies (conditional access, mTLS, client certificates, or equivalent). Where a policy exemption is required, record a formal risk acceptance with compensating controls.	ISS-012 - Endpoint Security Standard 5.4.9	Y	Y	Y	Y
32	Cloud Config & Network Security	Use standard landing zones, network patterns, and guardrails such as centrally managed VNets and policies where provided.	ISS-009 - Network Security Standard 5.1.2	Y	Y	Y	Y
33	Cloud Config & Network Security	Expose only required ports and protocols, and minimise internet-facing endpoints.	ISS-011 - Web Services Security Standard 4.10	Y	Y	Y	Y
34	Cloud Config & Network Security	Enforce preventive guardrails that block wide-open network rules (e.g., 0.0.0.0/0 or ::/0) and require least-privilege security group/firewall policies for admin and data-plane access; exceptions must be formally approved and time-bound.	ISS-009 - Network Security Standard 10.1.2	Y	Y	Y	Y
35	Cloud Config & Network Security	Ensure public-facing admin interfaces are protected behind VPN, bastion, or similar controlled access, not directly exposed to the internet.	ISS-001 - Cloud Computing Standard 4.3.8	Y	Y	Y	Y

ID	Category	Requirement	Standards Reference	SaaS	PaaS	IaaS	OnPrem
36	Datacentre Security	Implement layered physical access control (perimeter, building, room, rack) with named badge access, strong auth for secure areas, and regular access reviews.	ISS-004 - Asset Management Standard 4.3.2				Y
37	Datacentre Security	Maintain visitor management including pre-authorisation, ID verification, escort rules, and logging of access with retention per policy.	ISS-004 - Asset Management Standard 9.2				Y
38	Datacentre Security	Provide adequate CCTV coverage for entrances, racks, and critical areas and retain recordings according to policy.	ISS-009 - Network Security Standard 9.1.2				Y
39	Datacentre Security	Operate and monitor environmental controls (HVAC, fire detection and suppression, water/temperature sensors) with alerting into operations processes.	ISS-004 - Asset Management Standard 7.3				Y
40	Datacentre Security	Provide redundant power (UPS and generators where appropriate) and test power failover under load at scheduled intervals.	ISS-009 - Network Security Standard 4.1.1.3				Y
41	Datacentre Security	Define and exercise a site-loss plan describing how services will continue if the primary datacentre is unavailable, including secondary sites or cloud failover.	ISS-004 - Asset Management Standard 4.3.3				Y
42	Datacentre Security	Secure racks and cabinets with locks and implement cabling practices that prevent casual disconnection or interception of sensitive links.	ISS-009 - Network Security Standard 8.3.3				Y

ID	Category	Requirement	Standards Reference	SaaS	PaaS	IaaS	OnPrem
43	Encryption at Rest	Store all data at rest on encrypted storage using cloud provider encryption or RMG-approved KMS.	ISS-002 - Cryptography Standard 6	Y	Y	Y	Y
44	Encryption at Rest	Use RMG-approved key management/KMS for any custom keys and do not hardcode keys in code, images, or configuration files.	ISS-017 - Secret & Key Management Standard 4.2.5	Y	Y	Y	Y
45	Encryption at Rest	Define and enforce key rotation requirements for encryption keys (including CMKs) and ensure rotation is automated where supported; monitor and alert on key policy changes and anomalous key usage.	ISS-002 - Cryptography Standard 4.3	Y	Y	Y	Y
46	Encryption at Rest	Separate duties for key administration: restrict who can manage keys, who can use keys, and who can approve policy changes; periodically review key administrators and key grants.	ISS-002 - Cryptography Standard 4.3	Y	Y	Y	Y
47	Encryption in Transit	Ensure all external connections use TLS with RMG-approved ciphers/protocols; do not permit insecure protocols.	ISS-002 - Cryptography Standard 5	Y	Y	Y	Y
48	Encryption in Transit	Use TLS (or mTLS where mandated) for internal service-to-service calls carrying sensitive data, or an approved secure service mesh.	ISS-002 - Cryptography Standard 4	Y	Y	Y	Y
49	Encryption in Transit	Ensure TLS termination only occurs at approved ingress or load balancer components and is not bypassed at the application layer.	ISS-002 - Cryptography Standard 5.1	Y	Y	Y	Y

ID	Category	Requirement	Standards Reference	SaaS	PaaS	IaaS	OnPrem
50	Encryption in Transit	Manage certificates/PKI centrally: automate certificate issuance and renewal, prohibit expired/weak certificates, and enforce modern TLS configurations aligned to RMGal standards.	ISS-017 - Secret & Key Management Standard 4.6	Y	Y	Y	Y
51	Environment & Tenant Separation	Segregate data between tenants/customers logically or physically using separate databases, schemas, or robust row-level security.	ISS-009 - Network Security Standard 8.3.15	Y	Y	Y	Y
52	Environment & Tenant Separation	Enforce strict separation between environments (dev/test/stage/prod); do not share credentials, roles, or data without formal justification.	ISS-009 - Network Security Standard 8.3.4	Y	Y	Y	Y
53	Environment & Tenant Separation	Ensure admin access for one environment does not automatically imply access to others, particularly production.	ISS-001 - Cloud Computing Standard 4.4.7	Y	Y	Y	Y
54	Environment & Tenant Separation	For multi-tenant systems, enforce tenant isolation on every request to prevent cross-tenant data access.	ISS-009 - Network Security Standard 8.3.3	Y	Y	Y	Y
55	Governance & Exceptions	All deviations from these requirements must be captured in a formal risk acceptance with scope, compensating controls, approver, and expiry date; exceptions must be reviewed before expiry.	ISP-002 - Cyber Security Exception Procedure 11	Y	Y	Y	Y

ID	Category	Requirement	Standards Reference	SaaS	PaaS	IaaS	OnPrem
56	Hosts & Hardware (On-prem)	Maintain an accurate inventory of all servers, storage, and critical hardware with location, owner, support status, and data sensitivity.	ISS-012 - Endpoint Security Standard 5.6.2				Y
57	Hosts & Hardware (On-prem)	Harden server firmware, BIOS, and BMC by changing default credentials, disabling unnecessary management protocols, and restricting management networks.	ISS-012 - Endpoint Security Standard 4.2.14				Y
58	Hosts & Hardware (On-prem)	Enable and manage trusted boot, TPM, and hardware crypto capabilities where required and integrate them with key management processes.	ISS-012 - Endpoint Security Standard 4.2.15				Y
59	Hosts & Hardware (On-prem)	Apply regular firmware and microcode updates for servers and storage in line with vendor security advisories and change control.	ISS-012 - Endpoint Security Standard 4.6.5				Y
60	Hosts & Hardware (On-prem)	Enforce secure disposal of storage media through certified data wiping or physical destruction at end of life with evidence retained.	ISS-012 - Endpoint Security Standard 4.4.3				Y
61	Hosts & Hardware (On-prem)	Apply strong physical and logical controls to on-prem HSMs or key-management hardware including dual control, tamper resistance, and audited key operations.	ISS-009 - Network Security Standard 8.3.21				Y

ID	Category	Requirement	Standards Reference	SaaS	PaaS	IaaS	OnPrem
62	Identity & Directory (PaaS)	Integrate PaaS resources with central IAM and disable local users. Where a service requires local users, document the rationale, restrict access, rotate credentials, and monitor/alert on use.	ISS-013 - Authentication Standard 4.2.13		Y	Y	Y
63	Identity & Directory (PaaS)	Enforce SSO and MFA from the central IdP for all administrative access to PaaS management consoles and deployment pipelines.	ISS-001 - Cloud Computing Standard 4.3.1		Y	Y	Y
64	Identity & Directory (PaaS)	Use cloud IAM and policy to block disallowed PaaS services, regions, or SKUs and to enforce encryption, backup, and logging defaults.	ISS-001 - Cloud Computing Standard 4.3.8		Y	Y	Y
65	Identity & Directory (PaaS)	Define and implement resource-level RBAC (account/subscription, resource group, service) aligned to application roles, with clear owners for each scope.	POL-003 - Identity and Access Management Policy 2.1		Y	Y	Y
66	Inventory & Classification	Identify and document all data types processed (including personal data, special categories, financial data, secrets, and logs).	ISS-001 - Cloud Computing Standard 4.2.2	Y	Y	Y	Y
67	Inventory & Classification	Classify data according to RMG's classification scheme and label storage locations accordingly.	ISS-005 - Information Classification Standard 7	Y	Y	Y	Y
68	Inventory & Classification	Document key data flows: data sources, processing steps, destinations (including third parties/SaaS), and cross-border transfers.	ISS-001 - Cloud Computing Standard 4.2.2	Y	Y	Y	Y

ID	Category	Requirement	Standards Reference	SaaS	PaaS	IaaS	OnPrem
69	Inventory & Classification	Define which environments may hold production data; lower environments must use anonymised or synthetic data unless explicitly justified.	ISS-001 - Cloud Computing Standard 4.4.2	Y	Y	Y	Y
70	Least Privilege & SoD	Ensure default access for new users is the minimum required for their role; no broad or administrative access by default.	ISS-009 - Network Security Standard 5.1.1	Y	Y	Y	Y
71	Least Privilege & SoD	Separate administrative, support, and super-user functions into dedicated roles distinct from normal business roles.	POL-003 - Identity and Access Management Policy 4.6.3	Y	Y	Y	Y
72	Least Privilege & SoD	Enforce segregation of duties where required so that no single user can complete high-risk transactions end-to-end.	POL-003 - Identity and Access Management Policy 4.2.2	Y	Y	Y	Y
73	Least Privilege & SoD	Apply elevated assurance for highly privileged roles. At minimum: time-bound/JIT elevation, stronger device posture requirements, and enhanced logging/alerting for privileged actions; exceptions require formal approval and periodic revalidation.	ISS-009 - Network Security Standard 7.1.4	Y	Y	Y	Y
74	Least Privilege & SoD	Implement break-glass access for critical admin functions using dedicated accounts stored in an approved vault; require multi-party approval where feasible and alert on every use; test at defined intervals.	POL-003 - Identity and Access Management Policy 4.6.7	Y	Y	Y	Y

ID	Category	Requirement	Standards Reference	SaaS	PaaS	IaaS	OnPrem
75	Least Privilege & SoD	Enforce privileged access elevation via just-in-time workflows (or time-bound role assignments) and prohibit standing high-privilege access except via approved exceptions with expiry.	ISS-009 - Network Security Standard 10.1.2	Y	Y	Y	Y
76	Local Data on Endpoints	Minimise local storage of sensitive data on endpoints and cache only what is strictly necessary.	ISS-012 - Endpoint Security Standard 4.3.2	Y	Y	Y	Y
77	Local Data on Endpoints	If local storage is unavoidable, store data in OS/MDM-managed secure storage and ensure it is encrypted at rest.	ISS-012 - Endpoint Security Standard 5.3.1	Y	Y	Y	Y
78	Local Data on Endpoints	Use appropriate cache-control headers in web applications to prevent sensitive content being stored in browser caches longer than necessary.	ISS-008 - Mobile Security Standard 4.7.4	Y	Y	Y	Y
79	Logging & Sensitive Data	Prevent secrets, passwords, access tokens, and full payment card numbers from being written to logs.	ISS-006 Cyber Incident Management Standard 6.5	Y	Y	Y	Y
80	Logging & Sensitive Data	Where personal or sensitive data must appear in logs, ensure they are masked or truncated and document justification.	ISS-012 - Endpoint Security Standard 5.3.3	Y	Y	Y	Y
81	Logging & Sensitive Data	Ensure all security-relevant logs are ingested into central logging/SIEM.	ISS-020 - SIEM System Monitoring Standard 4.1	Y	Y	Y	Y

ID	Category	Requirement	Standards Reference	SaaS	PaaS	IaaS	OnPrem
82	Logging & Sensitive Data	Define minimum retention periods for security-relevant logs by system tier/data classification and ensure logs are retained centrally for that period with controlled access.	ISS-020 - SIEM System Monitoring Standard 4.3	Y	Y	Y	Y
83	Logging & Sensitive Data	Protect security logs from tampering: restrict delete/edit permissions, enable immutable/WORM storage for high-risk systems, and alert on log pipeline disruption or configuration changes.	ISS-020 - SIEM System Monitoring Standard 6.1	Y	Y	Y	Y
84	Logging & Sensitive Data	Implement data exfiltration monitoring for sensitive data flows (e.g., large downloads, bulk exports, unusual API access patterns) and require explicit approval and logging for bulk export functions.	ISS-012 - Endpoint Security Standard 5.3.3	Y	Y	Y	Y
85	Minimisation, Retention & Deletion	Justify each data element collected and avoid collecting unnecessary data.	ISS-004 - Asset Management Standard 9.2	Y	Y	Y	Y
86	Minimisation, Retention & Deletion	Define and implement retention rules for each data type, including legal/regulatory justification.	ISS-004 - Asset Management Standard 9.2	Y	Y	Y	Y
87	Minimisation, Retention & Deletion	Implement automated deletion or archiving aligned to retention schedules, including for derived datasets. Where automation is not technically feasible, implement a documented manual process with evidence (tickets/logs) and formal exception approval with an expiry date.	ISS-004 - Asset Management Standard 9.2	Y	Y	Y	Y

ID	Category	Requirement	Standards Reference	SaaS	PaaS	IaaS	OnPrem
88	Minimisation, Retention & Deletion	Provide a mechanism to delete or anonymise records for data subject or customer deletion requests where required.	ISS-004 - Asset Management Standard 9.2	Y	Y	Y	Y
89	Minimisation, Retention & Deletion	Document how deletion/rectification requests propagate to backups, archives, and logs (including any technical limitations) and define legal-hold behaviour that overrides deletion when required.	ISS-004 - Asset Management Standard 9.1	Y	Y	Y	Y
90	Monitoring, Detection & IR	Forward security-relevant logs (authentication events, privilege/admin actions, configuration/policy changes, key/secrets access, network allow/deny, critical application errors) to the central SIEM/logging platform using approved transport and ensure delivery is monitored for disruption.	ISS-020 - SIEM System Monitoring Standard 4.1	Y	Y	Y	Y
91	Monitoring, Detection & IR	Define what constitutes a security-relevant event for the system, such as repeated failed logins or unusual admin actions.	ISS-006 - Incident Management Standard 1.3	Y	Y	Y	Y
92	Monitoring, Detection & IR	Ensure logs contain sufficient context (request IDs, user IDs, tenant IDs) to support incident investigation.	ISS-006 - Incident Management Standard 3.4	Y	Y	Y	Y
93	Monitoring, Detection & IR	Provide documented runbooks or guidance for triaging common security incidents involving the system.	ISS-006 - Incident Management Standard 4.3	Y	Y	Y	Y

ID	Category	Requirement	Standards Reference	SaaS	PaaS	IaaS	OnPrem
94	Monitoring, Detection & IR	Synchronise system clocks to an approved time source and ensure logs include consistent, timezone-aware timestamps to support forensics.	ISS-006 Cyber Incident Management Standard 6.5.1	Y	Y	Y	Y
95	Monitoring, Detection & IR	Maintain an incident response plan for the service/system including roles, severity classification, escalation paths, communications, and evidence handling; link to enterprise IR processes.	ISS-006 Cyber Incident Management Standard 4.1.8	Y	Y	Y	Y
96	Monitoring, Detection & IR	Conduct incident response tabletop exercises at a defined cadence (at least annually for high-tier systems) and track remediation actions to closure with owners and due dates.	ISS-006 Cyber Incident Management Standard 4.1.8	Y	Y	Y	Y
97	Monitoring, Detection & IR	Define a minimum set of detection use cases and alerts for privileged access changes, authentication anomalies, policy/config changes, and suspected data exfiltration; ensure they are monitored with documented response playbooks.	ISS-006 - Incident Management Standard 3.4	Y	Y	Y	Y
98	Network (On-prem)	Design LAN/WAN with logical segmentation (user, server, management, DMZ, guest, OT) using VLANs and routing policies to avoid mixing untrusted and high-value assets.	ISS-009 - Network Security Standard 8.3.22				Y

ID	Category	Requirement	Standards Reference	SaaS	PaaS	IaaS	OnPrem
99	Network (On-prem)	Harden network devices (routers, switches, firewalls, wireless controllers) by using secure management protocols, central SSO for admin access, and no shared or default credentials.	ISS-009 - Network Security Standard 7.1.2				Y
100	Network (On-prem)	Implement network access control (e.g. 802.1X) and strong Wi-Fi authentication (WPA2-Enterprise/WPA3) to prevent rogue or unauthorised devices.	ISS-012 - Endpoint Security Standard 5.1.2				Y
101	Network (On-prem)	Encrypt sensitive WAN links (IPsec, MACsec, or equivalent) where traffic traverses untrusted networks.	ISS-009 - Network Security Standard 9.1.6				Y
102	Network (On-prem)	Monitor network devices for configuration changes, failures, and security events; send logs to the SIEM and store configuration backups under version control.	ISS-009 - Network Security Standard 7.1.4				Y
103	Network Controls (IaaS)	Design network segmentation for IaaS workloads to separate presentation, application, data, and management tiers and avoid flat networks for mixed trust levels.	ISS-009 - Network Security Standard 15.1.1			Y	Y
104	Network Controls (IaaS)	Design and implement workload network segmentation for IaaS (security groups/NACLs/firewalls) with explicit inbound/outbound rules per tier, deny-by-default for admin interfaces, and documented review of any broad rules; log and alert on changes to network policy.	ISS-009 - Network Security Standard 12.1.8			Y	Y

ID	Category	Requirement	Standards Reference	SaaS	PaaS	IaaS	OnPrem
105	Network Controls (IaaS)	Enable and monitor network flow logs, IDS/IPS (where used), and load balancer logs and forward them to the central SIEM.	ISS-009 - Network Security Standard 14.1.5			Y	Y
106	Network Controls (IaaS)	Implement DDoS protection for public-facing IaaS endpoints where the risk or traffic profile warrants it.	ISS-009 - Network Security Standard 11.1.1			Y	Y
107	Network Controls (IaaS)	Secure DNS, DHCP, and IP address management for IaaS by restricting admin access, logging configuration changes, and avoiding single points of failure.	ISS-001 - Cloud Computing Standard 5.1			Y	Y
108	Network Controls (IaaS)	For IaaS workloads, implement egress controls (default-deny or tightly scoped outbound rules) for high-tier systems and monitor for anomalous outbound destinations/volumes.	ISS-009 - Network Security Standard 5.1.5			Y	Y
109	Network Controls (PaaS)	Configure PaaS resources to use private connectivity by default (VNet/VPC integration, private endpoints) and disable public network access. Any public exposure must be approved via formal risk acceptance, include compensating controls (WAF, IP allow-list, strong authentication), and be reviewed periodically.	ISS-009 - Network Security Standard 14.1.4		Y	Y	Y
110	Network Controls (PaaS)	Front internet-exposed PaaS components with an application gateway/WAF and enforce HTTPS with modern TLS only.	ISS-009 - Network Security Standard 12.1.3		Y	Y	Y

ID	Category	Requirement	Standards Reference	SaaS	PaaS	IaaS	OnPrem
111	Network Controls (PaaS)	Restrict database and storage firewall rules to required subnets or private endpoints and prohibit broad rules such as 0.0.0.0/0.	ISS-009 - Network Security Standard 10.1.8		Y	Y	Y
112	Network Controls (PaaS)	Implement egress controls for PaaS workloads so outbound connections are restricted to approved destinations using firewalls or service tags.	ISS-009 - Network Security Standard 5.1.4		Y	Y	Y
113	Network Controls (PaaS)	Ensure PaaS resources inherit standard logging and flow-log settings so network and platform events are collected in the central SIEM.	ISS-009 - Network Security Standard 7.1.2		Y	Y	Y
114	Network Controls (PaaS)	Route outbound traffic through controlled egress points (e.g., NAT/proxy) and define an egress allow-list strategy for high-tier systems; log DNS queries and outbound connections for investigation.	ISS-009 - Network Security Standard 13.1.8		Y		Y
115	Non-human Identities & Secrets	Use managed identities, workload identities, or service principals instead of long-lived static keys wherever technically possible.	ISS-017 - Secret & Key Management Standard 4.2.2	Y	Y	Y	Y
116	Non-human Identities & Secrets	Avoid static credentials for non-human access by using workload identity/managed identity where supported. If static secrets are unavoidable, store them only in the central secrets manager, inject them at runtime, and rotate them at defined intervals (or via automation where supported).	ISS-017 - Secret & Key Management Standard 4.2.2	Y	Y	Y	Y

ID	Category	Requirement	Standards Reference	SaaS	PaaS	IaaS	OnPrem
117	Non-human Identities & Secrets	Implement automated rotation for non-human credentials where supported; where not supported, rotate at a defined interval (per policy) and on role change or suspected compromise, with evidence of completion.	POL-003 - Identity and Access Management Policy 4.2.13	Y	Y	Y	Y
118	Non-human Identities & Secrets	Scope non-human accounts to least privilege, granting only the minimal roles and permissions needed per component.	POL-003 - Identity and Access Management Policy 4.10.5	Y	Y	Y	Y
119	Operating System (IaaS)	Define hardened OS baselines for each OS type and ensure all virtual machines and images conform to the approved baseline.	ISS-012 - Endpoint Security Standard 5.4.2.1			Y	Y
120	Operating System (IaaS)	Use only approved base or golden images for virtual machines; disallow ad-hoc marketplace or user images without security review.	ISS-012 - Endpoint Security Standard 4.2.11			Y	Y
121	Operating System (IaaS)	Implement automated OS patching with defined SLAs for critical and high vulnerabilities and monitor patch compliance.	ISS-012 - Endpoint Security Standard 5.4.2			Y	Y
122	Operating System (IaaS)	Disable or remove unnecessary services, ports, and packages on all virtual machines and enforce host-based firewalls with least-privilege rules.	ISS-009 - Network Security Standard 5.1.5			Y	Y
123	Operating System (IaaS)	Ensure all virtual machines run approved EDR/anti-malware agents with tamper protection enabled and report their status into central monitoring.	ISS-012 - Endpoint Security Standard 5.5.1			Y	Y

ID	Category	Requirement	Standards Reference	SaaS	PaaS	IaaS	OnPrem
124	Operating System (IaaS)	Encrypt all VM disks, snapshots, and images using approved KMS keys and enforce encryption at rest by policy.	ISS-009 - Network Security Standard 9.1.4			Y	Y
125	Operating System (IaaS)	Lock down remote administration by using bastion or jump hosts, SSH keys instead of passwords, and controlled gateways for RDP; prohibit direct RDP/SSH from the internet and log admin access.	ISS-009 - Network Security Standard 8.3.22			Y	Y
126	Platform Services (PaaS)	Configure and regularly validate backup and restore settings for managed DBs, storage, and queues, including frequency, retention, and geo-replication where needed.	ISS-001 - Cloud Computing Standard 4.2.6		Y	Y	Y
127	Platform Services (PaaS)	Use customer-managed keys for PaaS services where risk or regulation requires and manage those keys through the central KMS lifecycle.	ISS-011 - Web Services Security Standard 3.6		Y	Y	Y
128	Platform Services (PaaS)	Define resource tagging standards (owner, data classification, environment, criticality) and enforce them via policy across all PaaS resources.	ISS-001 - Cloud Computing Standard 4.3.1		Y	Y	Y
129	Project-managed Compute	Use RMG standard images or base container images where mandated to inherit baseline hardening, EDR, and logging.	ISS-001 - Cloud Computing Standard 5.1	Y	Y	Y	Y
130	Project-managed Compute	Ensure all project-managed VMs/containers join RMG's patch and vulnerability management processes.	ISS-001 - Cloud Computing Standard 4.4.8	Y	Y	Y	Y

ID	Category	Requirement	Standards Reference	SaaS	PaaS	IaaS	OnPrem
131	Project-managed Compute	Do not run unsupported OS versions or end-of-life runtimes (e.g. EOL Java, Python, Node).	ISS-001 - Cloud Computing Standard 4.4.6	Y	Y	Y	Y
132	Project-managed Compute	For containerised workloads, enforce image scanning and admission controls so only approved, vulnerability-scanned, and (where required) signed images can run in production.	ISS-001 - Cloud Computing Standard 4.3.3		Y	Y	Y
133	Role & Permission Model	Define a clear role/permission model (RBAC/ABAC) for all user types including end users, admins, support, and integration accounts.	POL-003 - Identity and Access Management Policy 4.2.6	Y	Y	Y	Y
134	Role & Permission Model	Document mappings from business functions to application roles and to IdP groups or claims.	POL-003 - Identity and Access Management Policy 4.2.6	Y	Y	Y	Y
135	Role & Permission Model	Implement authorisation checks at every relevant layer (API, services, UI, and data access), not only in the UI.	ISS-013 - Authentication Standard 4.1.15	Y	Y	Y	Y
136	Secure Development & Deployment	Integrate with central CI/CD, code-scanning, and dependency-scanning tools where available.	ISS-001 - Cloud Computing Standard 4.4.8	Y	Y	Y	Y
137	Secure Development & Deployment	Ensure all code changes undergo peer review, with explicit focus on security-critical logic such as auth, crypto, and input validation.	ISS-015 - Cyber Security Testing Standard 5.5	Y	Y	Y	Y
138	Secure Development & Deployment	Perform threat modelling for the solution and address identified risks with specific controls or design changes.	ISS-014 - Secure Product Development Standard 4.3	Y	Y	Y	Y

ID	Category	Requirement	Standards Reference	SaaS	PaaS	IaaS	OnPrem
139	Secure Development & Deployment	Restrict who can approve deployments to higher environments, particularly production.	ISS-014 - Secure Product Development Standard 6.1	Y	Y	Y	Y
140	Secure Development & Deployment	Store Infrastructure-as-Code in version control, subject it to review, and scan for security misconfigurations.	ISS-014 - Secure Product Development Standard 4.8	Y	Y	Y	Y
141	Secure Development & Deployment	Run SAST on all code changes and enforce severity-based gates (e.g., block Critical/High findings unless an approved exception exists with expiry and compensating controls).	ISS-014 - Secure Product Development Standard 4.6	Y	Y	Y	Y
142	Secure Development & Deployment	Run dependency scanning (SCA) for third-party libraries and container base images; maintain an inventory/SBOM for each release and support rapid identification of impacted systems.	ISS-014 - Secure Product Development Standard 7.5	Y	Y	Y	Y
143	Secure Development & Deployment	Run DAST (or equivalent dynamic testing) for internet-facing applications/APIs on a defined cadence and before major releases; address findings within defined SLAs or formally accept risk.	ISS-001 - Cloud Computing Standard 4.3.6	Y	Y	Y	Y
144	Secure Development & Deployment	Perform independent penetration testing for internet-facing systems at least annually and after material architecture changes; track and remediate findings to SLA with formal exception handling.	ISS-011 - Web Services Security Standard 3.9	Y	Y	Y	Y

ID	Category	Requirement	Standards Reference	SaaS	PaaS	IaaS	OnPrem
145	Third-party & Supply Chain	Maintain an inventory of all third-party services, libraries, and APIs used by the project.	ISS-024 - Third Party Security Standard v1.0 4.2	Y	Y	Y	Y
146	Third-party & Supply Chain	Ensure any third-party SaaS handling sensitive data has passed RMG's vendor security or DPIA process.	ISS-024 - Third Party Security Standard v1.0 4.2	Y	Y	Y	Y
147	Third-party & Supply Chain	Pin or control third-party dependencies to avoid unexpected changes and apply security updates within defined SLAs.	ISS-024 - Third Party Security Standard v1.0 4.2	Y	Y	Y	Y
148	Third-party & Supply Chain	For any SaaS service used, the supplier must support RMG-approved SSO (SAML/OIDC) with enforced MFA via the central IdP and must allow disabling of local/standalone accounts.	ISS-001 - Cloud Computing Standard 4.3.10	Y			
149	Third-party & Supply Chain	For SaaS services, the supplier must support automated user provisioning and deprovisioning (e.g., SCIM) or provide an equivalent automated mechanism; deprovisioning must complete within a defined SLA.	ISS-001 - Cloud Computing Standard 4.3.12	Y			
150	Third-party & Supply Chain	For SaaS services, the supplier must provide admin/audit logs and security-relevant telemetry exportable to the central SIEM (API/webhook or supported connector) with defined event coverage (auth, admin actions, config changes).	ISS-001 - Cloud Computing Standard 5.3	Y			

ID	Category	Requirement	Standards Reference	SaaS	PaaS	IaaS	OnPrem
151	Third-party & Supply Chain	For SaaS services handling sensitive data, define and document data residency requirements and ensure the supplier provides sub-processor transparency and change notification within an agreed timeframe.	ISS-024 - Third Party Security Standard v1.0 4.2	Y			
152	Third-party & Supply Chain	For SaaS suppliers, contract terms must include security incident notification timelines, support for investigation (log access, evidence preservation), and clear RACI for containment/eradication actions.	ISP - 003 Cyber Security Third Party Assurance – Onboarding Process 2.11	Y			
153	Third-party & Supply Chain	For SaaS services, define an exit plan: data export format and cadence, validated restore/import path where required, and evidence of secure deletion on termination (including handling of backups where feasible).	ISS-001 - Cloud Computing Standard 6.1	Y			
154	Third-party & Supply Chain	Establish a SaaS tenant hardening baseline (admin roles, conditional access, approved integrations, external sharing controls, API token governance) and validate compliance at onboarding and periodically.	ISS-013 - Authentication Standard 4.1.15	Y			
155	Third-party & Supply Chain	Protect build integrity: restrict who can publish artifacts, sign release artifacts/images, and verify signatures at deploy time; store build provenance (e.g., SLSA-style attestations) for high-tier systems.	ISS-024 - Third Party Security Standard v1.0 4.2	Y	Y	Y	Y

ID	Category	Requirement	Standards Reference	SaaS	PaaS	IaaS	OnPrem
156	Workload Operations (IaaS)	Define a resource lifecycle process for IaaS workloads covering creation, change, ownership, and decommissioning to prevent orphaned resources.	ISS-001 - Cloud Computing Standard 5.1			Y	Y
157	Workload Operations (IaaS)	Ensure any self-managed orchestration platforms (e.g. self-hosted Kubernetes, OpenShift) meet security baselines including RBAC, network policies, image scanning, and secrets management.	ISS-009 - Network Security Standard 6.1.15			Y	Y
158	Workload Operations (IaaS)	Run regular vulnerability scans against IaaS workloads using central tooling where available and remediate findings within defined SLAs, tracking exceptions formally.	ISS-001 - Cloud Computing Standard 4.4.8			Y	Y
159	Workload Operations (IaaS)	Ensure backups and snapshots for IaaS workloads are encrypted, access-controlled, and protected from tampering or deletion, with restore procedures tested.	ISS-009 - Network Security Standard 9.4.1			Y	Y
160	Workload Operations (IaaS)	Document and test disaster recovery procedures for IaaS workloads, including rebuild from code/images in another region/account and data restoration.	ISS-003 - Data Backup and Restoration Standard 5.1.10			Y	Y
161	Workload Operations (IaaS)	Monitor cloud account quotas and limits (such as IP addresses, cores, storage) that could block incident response or disaster recovery and adjust proactively.	ISS-001 - Cloud Computing Standard 6			Y	Y



The above table should be used as a reference for the architecture that need to be met for the solution. The solution should meet all the requirements marked with "Y" in the "Mandatory" column based on the deployment platform. The solution

should also meet as many of the "Recommended" requirements as possible to enhance the security posture. Any deviations from the mandatory requirements must be documented with a formal risk acceptance, including compensating controls and an expiry date.

9.2. Data Flow Diagram / Threat Modelling

9.3. STRIDE Mitigation

Table 4. STRIDE Mitigation

STRIDE	Issue	Mitigation	Evidence
Spoofing	Spoofing: User Identity - Attacker pretends to be a legitimate OPG/COM user to access FDS. Spoofing: Service Identity - Attacker pretends to be a trusted upstream system (MQ/FTPS/JoinedUp).	Web Application Firewall (WAF) - Protects FDS frontend and APIs from common web attacks APIM Security Policies - Rate limiting, JWT validation, IP filtering, schema validation Role-Based Access Control (RBAC) - Ensures least-privilege access for users and services MQ Authentication & ACLs - Prevents spoofing and tampering on MQ channels, Service identity validation	
Tampering	Tampering: API Payloads - Modification of duty, timesheet or attendance data in transit. Tampering: Import Files - Modification of files sent via FTPS before ingestion.	TLS Encryption - Encrypts API traffic APIM Security Policies - Rate limiting, JWT validation, IP filtering, schema validation, Schema validation FTPS Hardening - Ensures secure file transfer with MFA, IP allowlists, and checksums, Checksums & secure transfer Input Validation - Prevents SQL injection and malformed payloads, Rejects malformed data	

STRIDE	Issue	Mitigation	Evidence
Repudiation	Repudiation: User Actions - Users deny having approved duties or timesheets. Repudiation: Admin Changes - Admins deny configuration or security-relevant changes.	Audit Logging - Captures user and admin actions for non-repudiation, Immutable logs, Admin activity logging' SIEM Monitoring - Detects anomalies, DoS attempts, tampering, and suspicious activity, Alerting on suspicious actions	
Information Disclosure	Information Disclosure: PII & HR Data - Exposure of personal and HR data from FDS DB and staging. Information Disclosure: Integration Data - Exposure of data in transit via MQ/FTPS/Data Platform.	TLS Encryption - Encrypts data in transit Encryption at Rest - Protects DB contents, Protects FDS DB, Staging DB, and exported files Azure Key Vault - Protects secrets, connection strings, certificates, Protects credentials Role-Based Access Control (RBAC) - Ensures least-privilege access for users and services, Restricts DB access	
Denial of Service (DoS)	DoS: Frontend & APIs - Overwhelming FDS frontend and APIs with traffic. DoS: Integration Channels - Flooding MQ/FTPS to disrupt data flows.	Web Application Firewall (WAF) - Protects FDS frontend and APIs from common web attacks, Blocks volumetric attacks APIM Security Policies - Rate limiting SIEM Monitoring - Detects MQ flooding	
Elevation of Privilege	Elevation of Privilege: Application - Exploiting application flaws to gain higher privileges. Elevation of Privilege: Database - Abusing DB permissions to bypass application controls.	Role-Based Access Control (RBAC) - Ensures least-privilege access for users and services, Restricts backend privileges Input Validation - Prevents injection Azure Key Vault - Protects DB credentials Encryption at Rest - Protects DB files	

9.4. Identity & Access Management (IAM)

This section should explain proposed authentication and authorization mechanism. It should include

Role Based Access Control (RBAC), Multi-factor Authentication (MFA) etc. with details around 3rd Party/Admin/Break Glass/Customer/User -User Access Matrix, Groups, Roles, Permissions, Access method, Secure Access Method, MFA etc.



A break glass account (or emergency access account) is a highly privileged IT account designed exclusively for emergencies. It acts as a digital failsafe to bypass standard security controls (like SSO, MFA, or Conditional Access policies) so administrators can restore system access if regular channels fail.

9.5. Data Categorization



Like PII, Finance, Customer, Intellectual Property etc

9.6. Usage of AI (If Applicable)



This should contain Purpose of AI (Use Case), Approved use of AI, Securing the AI etc.

9.7. Security RAID Log

ID	Type	Risk / Debt	Level	Mitigation

9.8. Application Business Criticality Rating

9.9. Quantum Cryptography Secure (TBC)

9.10. Active Directory Tier Level (TBC)

9.11. Privileged Access Requirements (CyberArk)

9.12. User Provisioning Requirement (SailPoint)

9.13. Key Management Services Requirements

10. Data Architecture

Content

Data architecture is the blueprint that dictates how an organization acquires, stores, transforms, distributes, and consumes data. It provides a standardized framework that connects business objectives to technical infrastructure, ensuring data is secure, consistent, scalable, and readily accessible for operations and AI applications.

Core Components

A robust data architecture consists of several interconnected building blocks:

- **Data Models:** Blueprints that map data structures, relationships, and business rules.
- **Data Flow & Pipelines:** Systems that ingest, process, and move data from sources to destinations.
- **Data Storage:** The repositories where data lives, such as Data Lakes, Data Warehouses, or Lakehouses.
- **Data Governance & Security:** Policies, standards, and access controls that maintain data quality and ensure regulatory compliance.

Motivation

A robust data architecture aligns data systems with business goals, providing a blueprint for data management, storage, and usage. Its core benefits include unified governance, improved data quality, and scalable infrastructure that accelerates real-time analytics and artificial intelligence (AI) adoption.

Key Benefits of Data Architecture

- **Eliminates Data Silos:** Unifies disparate systems, allowing departments to securely share data and establish a reliable "single version of the truth".
- **Enhanced Data Quality:** Enforces consistent data standards and validation rules to minimize duplication and prevent inaccurate reporting.
- **Scalability & Cost Optimization:** Optimizes cloud storage and data processing, reducing hardware needs and allocating operational resources efficiently.
- **Unified Governance & Compliance:** Implements centralized protocols to secure sensitive information and meet regulatory frameworks like GDPR.
- **Accelerated Innovation:** Provides a reliable, controlled foundation for advanced technologies like AI, machine learning, and real-time predictive analytics.

Form

*Data Architecture should be captured in form of **Data Models** and **Data Flow Diagrams** alongside a bunch of information captured in various tables and text paragraphs. The following sections outline the key information that should be captured for any new interface or data product created.*

10.1. Data Flow Diagram

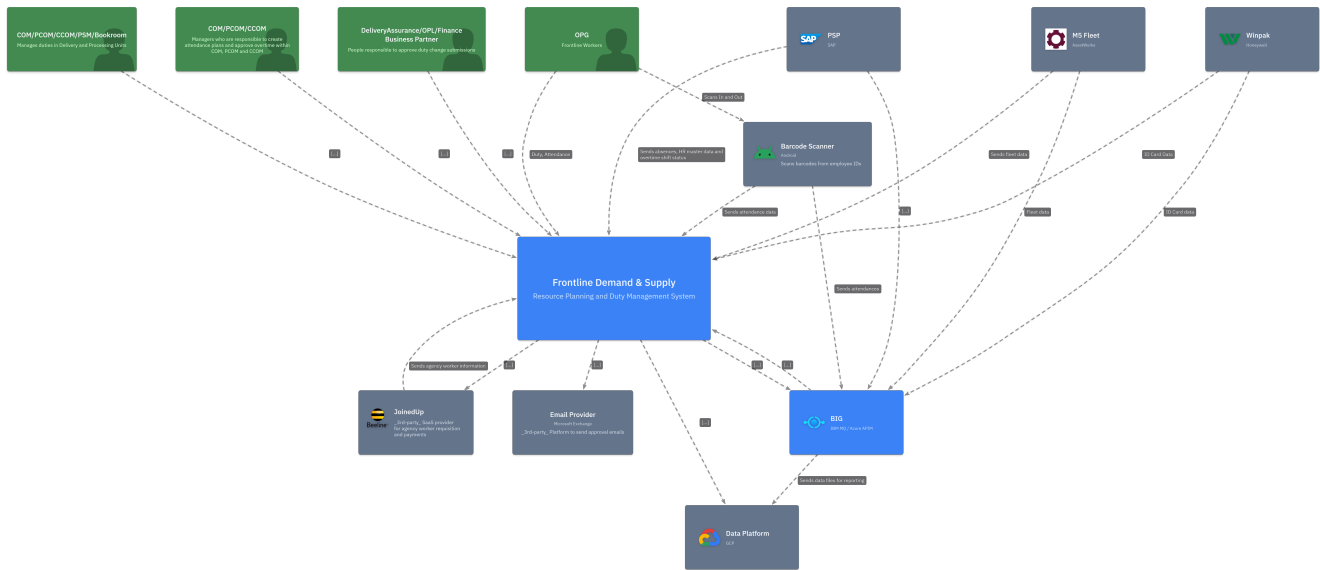


Figure 10. Data Flow Diagram - Level 0



For any new interface

10.2. Ownership model (data owner, data steward, data consumer)

Table 5. Data Ownership Model

Interface	Owner	Steward	Consumer

10.3. Policies: Data classification (public, internal, confidential, restricted), Retention (e.g., 5 years), Compliance (GDPR, HIPAA, etc.)

Table 6. Data Policies

Data Classification	
Data Categorization	
Retention Policy	
Data Compliance	

10.4. Data quality dimensions: Accuracy (e.g., 99%), completeness (e.g., 100%), timeliness (e.g., real-time), consistency (e.g., schema validation), uniqueness (e.g., no duplicates)

Table 7. Data Quality Dimensions

Accuracy	
Completeness	
Timeliness	
Consistency	
Uniqueness	
Volume	



Specify any new data product created or any of the existing data products used.
For each data product:

10.5. Purpose / business use case

10.6. Product owner (business + technical)

10.7. Consumers (teams, applications)

10.8. Value statement (why it exists)

10.9. Mapping between new interface and data product



Data Product Architecture

10.10. Data product boundaries (e.g., domain-specific, cross-domain)

10.11. Interaction between data products

10.12. Event-driven / batch flows

10.13. Storage layers (raw → curated → consumption)

In modern data platforms, the "Raw → Curated → Consumption" pipeline is a standardized approach to data organization, often referred to as the Medallion Architecture (Bronze → Silver → Gold). It ensures data integrity, minimizes pipeline fragility, and optimizes information for downstream analytics and machine learning.

- 1. Raw Layer (Landing/Bronze):** *The Raw layer is the initial entry point where ingested data from various sources (APIs, IoT, databases, logs) is stored in its native, unaltered format. Purpose: Acts as an immutable historical record and a source of truth that allows you to replay pipelines if errors occur downstream. Data State: Unprocessed, varying structures, frequently stored as JSON, CSV, or raw binary. Who interacts: Primarily used by data engineers.*
- 2. Curated Layer (Cleansed/Silver):** *The Curated layer sits between the raw and consumption layers, where raw data is transformed into validated, cleansed, and standardized datasets. Purpose: Establishes data reliability by removing duplicates, enforcing schema definitions, and applying business logic. Data State: Relational, standardized, and often partitioned into columnar formats like Parquet or Delta for better compression and query speed. Who interacts: Heavily accessed by data scientists and data analysts.*
- 3. Consumption Layer (Serving/Gold):** *The Consumption layer is the final destination, engineered specifically for business users, executives, and downstream applications. Purpose: Houses highly aggregated, project-specific data ready for business intelligence (BI) reporting, dashboards, and machine learning models. Data State: Denormalized, heavily structured (often into Star or Snowflake schemas), and read-optimized. Who interacts: Business analysts, executives, and client-facing applications.*

11. Cross-cutting Concepts

Content

This section describes crosscutting concepts (practices, patterns, regulations or solution ideas). Such concepts are often related to multiple building blocks.

Motivation

*Concepts form the basis for **conceptual integrity** (consistency, homogeneity) of the architecture. Thus, they are an important contribution to achieve inner qualities of your system.*

This is the place in the template that we provided for a cohesive specification of such concepts.

Many of these concepts relate to or influence several of your building blocks.

Form

The form can be varied:

- concept papers with any kind of structure
- example implementations, especially for technical concepts
- cross-cutting model excerpts or scenarios using notations of the architecture views

Structure

*Pick **only** the most-needed topics for your system and assign each a level-2 heading in this section (e.g. 8.1, 8.2 etc).*

11.1. <Concept 1>

<explanation>

11.2. <Concept 2>

<explanation>

...

11.3. <Concept n>

<explanation>



DO NOT ATTEMPT to cover all of the topics of the aforementioned diagram.

Further Information

Some topics within systems often concern multiple building blocks, hardware elements or

development processes. It might be easier to communicate or document such **cross-cutting** topics at a central location, instead of repeating them in the description of the concerned building blocks, hardware elements or development processes. Certain concepts might concern **all** elements of a system, others might only be relevant for a few. In the diagram above, logging concerns all three components, whereas security is relevant only for two components.

See [Concepts](#) in the arc42 documentation.

Royal Mail FDS - Processing Sites: Worked Example

11.4. Identity, Authentication and Authorisation

Authentication is delegated to Royal Mail AD via SAML; authorisation is enforced through AD groups including Planner-<of Location>, Approver-<of Location>, Book-room-<of Location>.

11.5. Audit and Traceability

An append-only audit store retains every state-changing action: plan amendments, OT/SA approvals, agency-timesheet submissions, and manual overrides. Each record carries actor identity, timestamp, source data references (scan event IDs, plan IDs). Retention is seven years, aligned with audit requirements.

11.6. Integration Resilience

All outbound integrations are idempotent and replayable. PSP and JoinedUp submissions use opaque idempotency keys derived from (employee, shift, approval-version). Dead-letter queues are monitored with alert thresholds.

11.7. Data Privacy and Retention

Personal data minimisation: only employee identifiers required for plan/scan/pay reconciliation are processed; names and full personal records remain in source systems. Retention schedules align with the RMG data-protection policy (7 years of archived data, 1 year of live data). Subject-access requests are serviceable through a support request.

11.8. Logging, Monitoring and Observability

Structured JSON logs, application metrics and distributed traces are emitted from every component and forwarded to the central observability platform. Service-level objectives (SLOs) for each capability are published; alerting is keyed off SLO burn rates rather than raw error counts. Operational dashboards expose plan-vs-scan reconciliation health, payroll backlog, and integration error rates.

11.9. User-experience consistency across the merged web app shell

The merger of the Deliveries and Processing shells (MDS_MVP16_01) is designed to be invisible to users: a single navigation, a single notification model, and a single search. Per-capability screens follow the existing Delivery patterns to minimise re-training cost for users moving between domains.

12. Architecture Decisions

Contents

Important, expensive, large scale or risky architecture decisions including rationales. With "decisions" we mean selecting one alternative based on given criteria.

Please use your judgement to decide whether an architectural decision should be documented here in this central section or whether you better document it locally (e.g. within the white box template of one building block).

Avoid redundancy. Refer to section 4, where you already captured the most important decisions of your architecture.



Only capture those decisions that deviates from well established patterns and practices. We also need to capture decisions where better option was available but we had to stick with approved pattern.

Motivation

Stakeholders of your system should be able to comprehend and retrace your decisions.

Form

Various options:

- ADR [Documenting Architecture Decisions](#) for every important decision
- List or table, ordered by importance and consequences or:
- more detailed in form of separate sections per decision

Royal Mail FDS - Processing Sites: Worked Example

12.1. ADR-001 - Reuse the existing FDS platform rather than build a new Processing system

Aspect	Detail
Status	Accepted
Context	Processing-site workforce planning needs a single, integrated, auditable platform. A net-new build would duplicate identity, audit, integration and reporting layers already proven in FDS for Deliveries.
Decision	Extend FDS; add Processing as additional bounded contexts within the existing solution.
Consequences	+ Faster delivery, lower TCO, consistency across front line planning. Increased coupling within the FDS solution; mitigated by clear bounded contexts and a published internal API contract.

12.2. ADR-002 - Merge the Deliveries and Processing SISO experiences

Aspect	Detail
Status	Accepted
Context	The current technical limitation prevents a user with Deliveries SISO access from also using Processing SISO (MDS_MVP16_01). This blocks shared-services users (e.g. cross-domain managers).
Decision	Implement a single web shell hosting both domains, governed by role-based authorisation.
Consequences	Removes the limitation; simpler user model.

12.3. ADR-003 - MDS remains the system of record for duty data

Aspect	Detail
Status	Accepted
Context	Authoring duty masters in two systems would create reconciliation problems and dilute the audit trail.
Decision	FDS holds an operational copy of MDS-owned duty data, refreshed monthly with on-demand deltas; FDS does not author duty masters.
Consequences	+ Single source of truth, simpler reconciliation. Latency between MDS amendment and FDS visibility; mitigated by on-demand refresh

12.4. ADR-004 - Duty-data viewing in FDS for MVP (MDS_MVP02_01/02)

Aspect	Detail
Status	Accepted
Context	PSMs can view duty data in FDS
Decision	FDS provides daily attendance plan screen for PSP to view and adjust the daily attendance plan for the processing site
Consequences	Sleeker planning solution available for the processing sites

12.5. ADR-005 - Enforce idempotency on all payroll-bound submissions

Aspect	Detail
Status	Accepted
Context	Duplicate payroll postings have direct financial and reputational consequences.
Decision	Every PSP and JoinedUp submission carries a deterministic idempotency key; the receiver-side or our outbound adapter rejects duplicates.
Consequences	+ Pay accuracy protected during retries and outages.

13. Quality Requirements

Content

This section contains all relevant quality requirements.

*The most important of these requirements have already been described in section 1.2. (quality goals), therefore they should only be referenced here. In this section 10 you should also capture quality requirements with lesser importance, which will not create high risks when they are not fully achieved (but might be **nice-to-have**).*

Motivation

Since quality requirements will have a lot of influence on architectural decisions you should know what qualities are really important for your stakeholders, in a specific and measurable way.

13.1. Quality Requirements Overview

Content

An overview or summary of quality requirements.

This section should provide an overview of quality requirements at a category level (Like performance, scalability, interoperability, security etc.) and how those requirements are met by the proposed architecture

Motivation

Often we encounter dozens (or even hundreds) of detailed quality requirements. In this overview section you should try to summarize, e.g. by describing categories or topics (as suggested by [ISO 25010:2023](#) or [Q42](#))

If these summary descriptions are already precise, specific enough and measurable, you may skip section 10.2.

Form

*Use a simple table in which each line contains a category or topic and a short description of the quality requirement. Alternatively, you may use a mind map to structure these quality requirements. In literature, the idea of a **quality attribute tree** has also been described, which puts the generic term "quality" as the root and uses a tree-like refinement of the term "quality". [Bass+21] introduced the term "**Quality Attribute Utility Tree**" for this purpose.*

Royal Mail FDS - Processing Sites: Worked Example

Category (ISO 25010)	Quality requirement
Functional Suitability	All MVP capabilities operate to the acceptance criteria defined in user stories; no critical defect open at go-live.

Category (ISO 25010)	Quality requirement
Performance Efficiency	Daily Attendance Plan view loads in $\leq 2s$ at 95th percentile; OT Timesheet queue loads in $\leq 3s$ for a typical Mail Centre payload.
Compatibility	Compatible with Royal Mail standard browser estate (Edge current and current-1, Chrome current and current-1).
Usability	PSM full-shift adjustment under 90s
Reliability	Service availability 99.7% in the operational window; payroll-egress completeness 100% (with latency tolerance).
Security	Sonarqube Reporting on the code with no high and critical issues, remediation plan for medium issues. Annual penetration test; quarterly access-rights review Encryption in transit and at rest.
Maintainability	Each component independently buildable, testable, deployable; codebase coverage target 70%+.

13.2. Quality Scenarios (selected)

Content

Quality scenarios make quality requirements concrete and allow to decide whether they are fulfilled (in the sense of acceptance criteria). Ensure that your scenarios are specific and measurable.

This section is complementary to NFRs defined in LeanIX. This provides an acceptance criteria for each NFR that could be tested. The distinction between an NFR and Quality Scenarios could be understood with the following examples:

NFR – All PII data should be encrypted at rest

Quality Scenario – All PII data should be encrypted using AES256 before storing in the database.

In the above example – Just by looking at the NFR alone, we cannot test it but the associated quality scenario makes it testable

NFR – All save operations should be complete in less than 5 seconds

Quality Scenario – Upon clicking on Save button on employee edit screen, record should be saved within 3 seconds and success message should be displayed on the screen.

*Key point here is “**measurable**”. We can link either LeanIX or any other form of document(s) where these quality scenarios are captured.*

Two kinds of scenarios are especially useful:

- **Usage scenarios** (also called application scenarios or use case scenarios) describe the system's runtime reaction to a certain stimulus. This also includes scenarios that describe the system's efficiency or performance. Example: The system reacts to a user's request within one second.
- **Change scenarios** describe the desired effect of a modification or extension of the system or of its immediate environment. Example: Additional functionality is implemented or requirements for a quality attribute change, and the effort or duration of the change is measured.

Form

Typical information for detailed scenarios include the following:

In short form (favoured in the Q42 model):

- **Context/Background:** What kind of system or component, what is the environment or situation?
- **Source/Stimulus:** Who or what initiates or triggers a **behaviour**, **reaction** or **action**.
- **Metric/Acceptance Criteria:** A response including a **measure** or **metric**.

The long form of scenarios (favoured by the SEI and [Bass+21]) is more detailed and includes the following information:

- **Scenario ID:** A unique identifier for the scenario.
- **Scenario Name:** A short, descriptive name for the scenario.
- **Source:** The entity (user, system, or event) that initiates the scenario.
- **Stimulus:** The triggering event or condition the system must address.
- **Environment:** The operational context or condition under which the system experiences the stimulus.
- **Artifact:** The building-blocks or other elements of the system affected by the stimulus.
- **Response:** The outcome or behavior the system exhibits in reaction to the stimulus.
- **Response Measure:** The criteria or metric by which the system's response is evaluated.

Royal Mail FDS - Processing Sites: Worked Example

13.2.1. QS-01 - Morning peak load

Aspect	Detail
Source / Stimulus	Concurrent login of 600 PSMs/WAMs across UK processing sites, Concurrent login of 800 COM across UK delivery sites within a 30-minute window.
Environment	Production, normal-day load profile.
Artifact	Web shell application
Response	All users authenticated and able to view and modify current weeks plan.
Response measure	≥ 99% of logins succeed within 5 seconds; Attendance plan load ≤ 2 seconds.

13.2.2. QS-02 - MQ outage degraded-mode

Aspect	Detail
Source / Stimulus	OT IBM MQ connection error for a sustained period of 10 minutes.
Environment	Production.
Artifact	FDS Queue Manager, BIG IBM MQ
Response	Approvals continue to be captured in FDS; submissions queued durably; back-off retry; users informed of egress backlog without blocking.
Response measure	Zero pay records lost; backlog drains within 120 minutes of MQ recovery; no duplicate submissions.

13.2.3. QS-03 - Audit retrieval

Aspect	Detail
Source / Stimulus	Internal audit requests the full approval trail for a specific OT payment from 12 months ago.
Environment	Production.
Artifact	Audit & Logging
Response	The audit trail is retrieved with all linked scan and plan references.
Response measure	Retrieval ≤ 10 seconds; trail completeness 100%; tamper-evidence verified

14. RAID Log and Technical Debts

Contents

A list of identified technical risks, issues and technical debts, ordered by priority alongside mitigation plan for each one of them

Arc42 says to log risks here as rest of the things (Assumptions, Issues and Dependencies) are project management tools.

Assumptions and dependencies anyway should be gone before Gate 5 because if these are not resolved by then, they become risks or issues to the project.



We do not want to remove assumptions and dependencies but these must be linked to respective risks and issues

Motivation

Risk management is project management for grown-ups

— Tim Lister, Atlantic Systems Guild

This should be your motto for systematic detection and evaluation of risks and technical debts in the architecture, which will be needed by management stakeholders (e.g. project managers, product owners) as part of the overall risk analysis and measurement planning.

Form

List of risks and/or technical debts, probably including suggested measures to minimize, mitigate or avoid risks or reduce technical debts.

Royal Mail FDS - Processing Sites: Worked Example

ID	Type	Risk / Debt	Level	Mitigation
R-01	Risk	Pre-existing technical limitation between Deliveries SISO and Processing SISO (cross-access) increases regression scope of the merger (MDS_MVP16_01).	Medium	Phased rollout behind a feature flag; explicit regression suite for cross-domain users; PRE-PROD soak with shadow traffic.
R-02	Risk	MDS bulk import on a monthly cadence creates blind windows for in-month duty changes.	Low	On-demand delta import endpoint; Duty Revision Workflow bridges in-month changes with audit. Plan to deploy the Duty composition capability in FDS for processing sites

ID	Type	Risk / Debt	Level	Mitigation
R-03	Tech Debt	Custom point to point integration with MDS using SharePoint since MDS (excel) doesn't have a capability to connect to a SFTP site	Low	Plan to decommission the MDS and bring its capability fully into FDS
R-04	Risk	Performance under operational peaks, particularly Christmas pressure period (Q4).	High	Capacity test against a peak-traffic profile in

15. Glossary

Contents

The most important domain and technical terms that your stakeholders use when discussing the system. You can also see the glossary as source for translations if you work in multi-language teams.

Motivation

You should clearly define your terms, so that all stakeholders

- have an identical understanding of these terms
- do not use synonyms and homonyms

Form

*A table with columns **<Term>** and **<Definition>**. Potentially more columns in case you need translations.*

Royal Mail FDS - Processing Sites: Worked Example

Term	Definition
AWD	Authorised Working Directive - an employee's contracted standard working day; the baseline against which OT and SA are measured.
Book Room	Site administrative function holding attendance and pay-related records; an authorised approver for OT timesheets.
Console	Fixed terminal at a Processing Site capturing employee scan-on / scan-off events.
DP	Royal Mail enterprise Data Platform deployed on GCP - the strategic landing zone for analytical data feeds; visualised primarily through Qlik.
Duty	A defined scheduled role at a site, with associated work-area splits and rotation pattern.
Duty Holder	The employee allocated to a duty for a given week of rotation.
FDS	Front Line Demand and Supply - the Royal Mail platform for workforce planning across the front-line estate.
JoinedUp	Third party SaaS platform used by RMG for requesting agency worker, also the destination for approved agency timesheets.
MDS	Master Duty System - the system of record for duty masters and reference data.
MoSCoW	Prioritisation taxonomy: Must-have, Should-have, Could-have, Won't-have.
MVP	Minimum Viable Product - the smallest release delivering meaningful value.

Term	Definition
OT	Overtime - work performed beyond the AWD, requiring planning, approval and pay processing.
PDA	Personal Digital Assistant - handheld device used by front-line staff for scan operations.
Plan-vs-Scan	The reconciliation pattern comparing approved plans against PDA/Console scan data.
Processing Site	Mail Centres, Hubs and Super Hubs in scope of this HLD.
PSM	Processing Site Manager - primary daily user of FDS at a processing site.
PSP	Royal Mail's payroll system
Qlik Cloud	Royal Mail's strategic visualisation platform for operational and finance reporting.
RCS	Resource Control System for reporting to the planned vs actual hours used by in a site for cost governance.
SA	Schedule Attendance against pre-scheduled non-AWD shifts requiring approval and pay processing.
Site Loan	The borrowing of an employee from another site to cover demand; supported via the attendance plan.
WAM	Work Area Manager operational manager of a defined work area within a Processing Site.